

NIST SP 800-171 Rev 3 control 03.13.11 (03.13.11 Cryptographic Protection) requires organizations to implement the following: 03.13.11 · Cryptographic Protection Supplemental Guidance: Cryptography is implemented in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, and guidelines. FIPS-validated cryptography is recommended for the protection of CUI. Assessment Objectives: - the following types of cryptography are implemented to protect the confidentiality of CUI: [organization-defined parameter]. Organization-Defined Parameters: - A.03.13.11.ODP.01: types of cryptograph For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.11.

NIST SP 800-53 Rev 5 control SC-4 (Information in Shared System Resources) is assessed by examining, interviewing, and testing: SC-4 · Information in Shared System Resources Control Statement: Prevent unauthorized and unintended information transfer via shared system resources. Supplemental Guidance: Prevent unauthorized and unintended information transfer via shared system resources. Preventing unauthorized and unintended information transfer via shared system resources stops information produced by the actions of prior users or roles (or the actions of processes acting on behalf of prior users or roles) from being av

SC.L2-3.13.12 · Collaborative Device Control CMMC Assessment Guide · Level 2 | Version 2.13 237
FURTHER DISCUSSION Notification that a device is in use can include an indicator light that turns on or a specific text window that appears on screen. If a device does not have the means to alert a user when in use, the organization should provide manual means. Manual means can include, as necessary: · paper notification on entryways; and · locking entryways when a collaborative computing device is in use. This requirement is not intended to include technologies that enable users to share the contents of their computer screens via the internet. Example A group of remote employees at your company routinely collaborate using cameras and microphones attached to their computers [a]. To prevent the misuse of these devices, you disable the ability to turn on cameras or microphones remotely [c]. You ensure the machines alert users when the camera or microphone are in use with a light beside the camera and an onscreen notification [b]. Although remote activation is blocked, this enables users to see if the devices are active. Potential Assessment Considerations · Are the collaborative computing devices configured to provide indication to users when in use (e.g., a light, text notification, or audio tone) or are users alerted before entering a space (e.g., written notice posted outside the space) where they are in use [b]? · Are the collaborative computing devices configured to prevent them from being turned on without user interaction or consent [c]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.13.12

NIST SP 800-171 Rev 3 control 03.13.01 (03.13.01 Boundary Protection) requires organizations to implement the following: Control Statement: SR-03.13.01.a Monitor and control communications at external managed interfaces to the system and key internal managed interfaces within the system. SR-03.13.01.b Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks. SR-03.13.01.c Connect to external systems only through managed interfaces that consist of boundary protection devices arranged in accordance with an organizational security architecture. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.01.

NIST SP 800-53 Rev 5 control SC-12.3 (Asymmetric Keys) is assessed by examining, interviewing, and testing: SC-12.3 · Asymmetric Keys Control Statement: Produce, control, and distribute asymmetric cryptographic keys using [organization-defined parameter]. Supplemental Guidance: Produce, control, and distribute asymmetric cryptographic keys using [organization-defined parameter]. [SP 800-56A](#20957dbb-6a1e-40a2-b38a-66f67d33ac2e), [SP 800-56B](#0d083d8a-5cc6-46f1-8d79-3081d42bcb75), and [SP 800-56C](#eef62b16-c796-4554-955c-505824135b8a) provide guidance on cryptographic key establishment schemes a

NIST SP 800-53 Rev 5 control SC-3.3 (Minimize Nonsecurity Functionality) is assessed by examining, interviewing, and testing: SC-3.3 · Minimize Nonsecurity Functionality Control Statement: Minimize the number of nonsecurity functions included within the isolation boundary containing security functions. Supplemental Guidance: Minimize the number of nonsecurity functions included within the isolation boundary containing security functions. Where it is not feasible to achieve strict isolation of nonsecurity functions from security functions, it is necessary to take actions to

minimize nonsecurity-relevant functions with

NIST SP 800-171 Rev 3 control 03.13.13 (03.13.13 Mobile Code) requires organizations to implement the following: Control Statement: SR-03.13.13.a Define acceptable mobile code and mobile code technologies. SR-03.13.13.b Authorize, monitor, and control the use of mobile code. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.13.

SC-50 · Software-enforced Separation and Policy Enforcement Control Statement: Implement software-enforced separation and policy enforcement mechanisms between [organization-defined parameter]. Supplemental Guidance: Implement software-enforced separation and policy enforcement mechanisms between [organization-defined parameter]. System owners may require additional strength of mechanism to ensure domain separation and policy enforcement for specific types of threats and environments of operation.

NIST SP 800-171 Rev 3 control 03.13.10 (03.13.10 Cryptographic Key Establishment and Management) is assessed by examining the following: Assessment Objectives: - cryptographic keys are established in the system in accordance with the following key management requirements: [organization-defined parameter]. - cryptographic keys are managed in the system in accordance with the following key management requirements: [organization-defined parameter].

NIST SP 800-53 Rev 5 control SC-39 (Process Isolation) is assessed by examining, interviewing, and testing: SC-39 · Process Isolation Control Statement: Maintain a separate execution domain for each executing system process. Supplemental Guidance: Maintain a separate execution domain for each executing system process. Systems can maintain separate execution domains for each executing process by assigning each process a separate address space. Each system process has a distinct address space so that communication between processes is performed in a manner controlled through the security functions, an

NIST SP 800-53 Rev 5 control SC-3.3 (Minimize Nonsecurity Functionality) summarizes the requirements for this control: SC-3.3 · Minimize Nonsecurity Functionality Control Statement: Minimize the number of nonsecurity functions included within the isolation boundary containing security functions. Supplemental Guidance: Minimize the number of nonsecurity functions included within the isolation boundary containing security functions. Where it is not feasible to achieve strict isolation of nonsecurity functions from security functions, it is necessary to take actions to minimize nonsecurity-relevant functions with

NIST SP 800-53 Rev 5 control SC-11.1 (Irrefutable Communications Path) is assessed by examining, interviewing, and testing: SC-11.1 · Irrefutable Communications Path Control Statement: (a) Provide a trusted communications path that is irrefutably distinguishable from other communications paths; and (b) Initiate the trusted communications path for communications between the [organization-defined parameter] of the system and the user. Supplemental Guidance: (a) Provide a trusted communications path that is irrefutably distinguishable from other communications paths; and (b) Initiate the trusted communications path fo

Under the FedRAMP Low baseline, SC-13 (SC-13 Cryptographic Protection): FedRAMP Low Baseline · SC-13 · Cryptographic Protection Control Statement: a. Determine the [organization-defined parameter] ; and b. Implement the following types of cryptography required for each specified cryptographic use: [organization-defined parameter]. Supplemental Guidance: a. Determine the [organization-defined parameter] ; and b. Implement the following types of cryptography required for each specified cryptographic use: [organization-defined parameter]. Cryptography can be employed

NIST SP 800-53 Rev 5 control SC-7.14 (Protect Against Unauthorized Physical Connections): SC-7.14 · Protect Against Unauthorized Physical Connections Control Statement: Protect against unauthorized physical connections at [organization-defined parameter]. Supplemental Guidance: Protect against unauthorized physical connections at [organization-defined parameter]. Systems that operate at different security categories or classification levels may share common physical and environmental

Under the FedRAMP Moderate baseline, SC-28.1 (SC-28.1 Cryptographic Protection): FedRAMP Moderate Baseline · SC-28.1 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms

to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. The

NIST SP 800-171 Rev 3 control 03.13.08 (03.13.08 Transmission and Storage Confidentiality) is assessed by examining the following: Assessment Objectives: - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI during transmission. - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI while in storage.

NIST SP 800-53 Rev 5 control SC-36.1 (Polling Techniques) summarizes the requirements for this control: SC-36.1 · Polling Techniques Control Statement: (a) Employ polling techniques to identify potential faults, errors, or compromises to the following processing and storage components: [organization-defined parameter] ; and (b) Take the following actions in response to identified faults, errors, or compromises: [organization-defined parameter]. Supplemental Guidance: (a) Employ polling techniques to identify potential faults, errors, or compromises to the following processing and storage compone

NIST SP 800-171 Rev 3 control 03.13.06 (03.13.06 Network Communications · Deny by Default · Allow by Exception) falls under the System and Communications Protection family. 03.13.06 · Network Communications · Deny by Default · Allow by Exception Supplemental Guidance: This requirement applies to inbound and outbound network communications traffic at the system boundary and at identified points within the system. A deny-all, allow-by-exception network communications traffic policy ensures that only essential and approved connections are allowed. Assessment Objectives: - network communications traffic is denied by default. - network communications traffic is allowe Supplemental Guidance: This requirement applies to inbound and outbound network communications traffic at the system boundary and at identified points within the system. A deny-all, allow-by-exception network communications traffic policy ensures that only essential and approved connections are allowed.

SC-40.1 · Electromagnetic Interference Control Statement: Implement cryptographic mechanisms that achieve [organization-defined parameter] against the effects of intentional electromagnetic interference. Supplemental Guidance: Implement cryptographic mechanisms that achieve [organization-defined parameter] against the effects of intentional electromagnetic interference. The implementation of cryptographic mechanisms for electromagnetic interference protects systems against intentional jamming that might deny or impair communications by ensuring that wireless spread spectrum waveforms used to provide anti-jam protection are not predictable by unauthorized individuals. The implementation of cryptographic mechanisms may also coincidentally mitigate the effects of unintentional jamming due to interference from legitimate transmitters that share the same spectrum. Mission requirements, projected threats, concept of operations, and laws, executive orders, directives, regulations, policies, and standards determine levels of wireless link availability, cryptography needed, and performance.

NIST SP 800-53 Rev 5 control SC-48 (Sensor Relocation) summarizes the requirements for this control: SC-48 · Sensor Relocation Control Statement: Relocate [organization-defined parameter] to [organization-defined parameter] under the following conditions or circumstances: [organization-defined parameter]. Supplemental Guidance: Relocate [organization-defined parameter] to [organization-defined parameter] under the following conditions or circumstances: [organization-defined parameter]. Adversaries may take various paths and use different approaches as they move laterally through an organizati

NIST SP 800-53 Rev 5 control SC-7.27 (Unclassified Non-national Security System Connections) is defined as follows: SC-7.27 · Unclassified Non-national Security System Connections Control Statement: Prohibit the direct connection of [organization-defined parameter] to an external network without the use of [organization-defined parameter]. Supplemental Guidance: Prohibit the direct connection of [organization-defined parameter] to an external network without the use of [organization-defined parameter]. A direct connection is a dedicated physical or virtual connection between two or more systems. Organizations typically do not have complete control over external networks, including the Internet. Boundary p

a Level 3 data enclave with greater restrictions and protections within a Level 2 data enclave. Any Level 2 POA&M items must be closed prior to the initiation of the CMMC Level 3 Certification Assessment. DCMA DIBCAC may check any Level 2 security requirement of any in-scope asset, and if they determine a requirement is NOT MET, DCMA DIBCAC may allow for remediation or may immediately terminate the Level 3 Assessment. For further information or to contact DCMA DIBCAC regarding CMMC, please refer to <https://www.dcma.mil/DIBCAC/> or email dcma_dibcac_cmmc@mail.mil. §-170.20 Standards acceptance. (a) NIST SP 800-171 Rev 2 DoD assessments. In order to avoid duplication of efforts, thereby reducing the aggregate cost to industry and the Department, OSCs that have completed a DCMA DIBCAC High Assessment aligned with CMMC Level 2 Scoping will be eligible for CMMC Level 2 Final Certification Assessment under the following conditions: (1) DCMA DIBCAC High Assessment. An OSC that achieved a perfect score with no open POA&M from a DCMA DIBCAC High Assessment conducted prior to the effective date of this rule, is eligible for a CMMC Level 2 Final Certification Assessment with a validity period of three (3) years from the date of the original DCMA DIBCAC High Assessment. Eligible DCMA DIBCAC High Assessments include ones conducted with Joint Surveillance in accordance with the DCMA Manual 2302-01 Surveillance. The scope of the CMMC Level 2 Final Certification Assessment is identical to the scope of the DCMA DIBCAC High Assessment. In accordance with §-170.17, the OSC must also submit an affirmation in SPRS and annually thereafter to achieve contractual eligibility. (2) [Reserved] (b) [Reserved] §-170.21 Plan of Action and Milestones requirements. (a) POA&M. An OSA shall maintain a POA&M, as applicable, as part of operations under the security requirement for Risk Assessments and Continuous Monitoring (CA.L2-3.12.2) for CMMC Levels 2 and 3 in accordance with §-170.14(c)(3) and (4), respectively. For purposes of conducting a CMMC assessment and satisfying the contractual eligibility requirements for CMMC Level 1, 2, or 3, an OSA is only permitted to have a POA&M for select requirements scored as NOT MET during the CMMC assessment and only under the following conditions: (1) CMMC Level 1 Self-Assessment. A POA&M is not permitted at any time for CMMC Level 1 Self-Assessments (2) CMMC Level 2 Self-Assessment and CMMC Level 2 Certification Assessment. An OSA is only permitted to have a POA&M for CMMC Level 2 if all the following conditions are met: (i) The assessment score divided by the total number of security requirements is greater than or equal to 0.8; (ii) None of the security requirements included in the POA&M have a point value of greater than 1 as specified in the CMMC Scoring Methodology set forth in §-170.24, except SC.L2-3.13.11 CUI Encryption may be included on a POA&M if it has a value of 1 or 3; and (iii) None of the following security requirements are included in the POA&M:

NIST SP 800-53 Rev 5 control SC-7.14 (Protect Against Unauthorized Physical Connections) summarizes the requirements for this control: SC-7.14 · Protect Against Unauthorized Physical Connections Control Statement: Protect against unauthorized physical connections at [organization-defined parameter]. Supplemental Guidance: Protect against unauthorized physical connections at [organization-defined parameter]. Systems that operate at different security categories or classification levels may share common physical and environmental controls, since the systems may share space within the same facilities. In practice, it is possible

NIST SP 800-53 Rev 5 control SC-23 (Session Authenticity) is assessed by examining, interviewing, and testing: SC-23 · Session Authenticity Control Statement: Protect the authenticity of communications sessions. Supplemental Guidance: Protect the authenticity of communications sessions. Protecting session authenticity addresses communications protection at the session level, not at the packet level. Such protection establishes grounds for confidence at both ends of communications sessions in the ongoing identities of other parties and the validity of transmitted information. Authenticity protection inc

Under the FedRAMP Low baseline, SC-28 (SC-28 Protection of Information at Rest): FedRAMP Low Baseline · SC-28 · Protection of Information at Rest Control Statement: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Supplemental Guidance: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Information at rest refers to the state of information when it is not in process or in transit and is located on system components. Such components include i

NIST SP 800-53 Rev 5 control SC-30.2 (Randomness) is assessed by examining, interviewing, and testing: SC-30.2 · Randomness Control Statement: Employ [organization-defined parameter] to introduce randomness into organizational operations and assets. Supplemental Guidance: Employ

[organization-defined parameter] to introduce randomness into organizational operations and assets. Randomness introduces increased levels of uncertainty for adversaries regarding the actions that organizations take to defend their systems against attacks. Such actions may impede the ability of adversaries to correctly

NIST SP 800-53 Rev 5 control SC-21 (Secure Name/Address Resolution Service (Recursive or Caching Resolver)) is assessed by examining, interviewing, and testing: SC-21 · Secure Name/Address Resolution Service (Recursive or Caching Resolver) Control Statement: Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources. Supplemental Guidance: Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources. Each client of name resolution services e

NIST SP 800-171 Rev 3 control 03.13.12 (03.13.12 Collaborative Computing Devices and Applications) is assessed by examining the following: Assessment Objectives: - the remote activation of collaborative computing devices and applications is prohibited with the following exceptions: [organization-defined parameter]. - an explicit indication of use is provided to users who are physically present at the devices.

FedRAMP Low Baseline · SC-8.1 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to [organization-defined parameter] during transmission. Supplemental Guidance: Implement cryptographic mechanisms to [organization-defined parameter] during transmission. Encryption protects information from unauthorized disclosure and modification during transmission. Cryptographic mechanisms that protect the confidentiality and integrity of information during transmission include TLS and IPsec. Cryptographic mechanisms used to protect information integrity include cryptographic hash functions that have applications in digital signatures, checksums, and message authentication codes. Assessment Objectives: Implement cryptographic mechanisms to [organization-defined parameter] during transmission.

NIST SP 800-171 Rev 3 control 03.13.12 (03.13.12 Collaborative Computing Devices and Applications) requires organizations to implement the following: Control Statement: SR-03.13.12.a Prohibit the remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter]. SR-03.13.12.b Provide an explicit indication of use to users physically present at the devices. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.12.

NIST SP 800-53 Rev 5 control SC-18.3 (Prevent Downloading and Execution) is assessed by examining, interviewing, and testing: SC-18.3 · Prevent Downloading and Execution Control Statement: Prevent the download and execution of [organization-defined parameter]. Supplemental Guidance: Prevent the download and execution of [organization-defined parameter]. None.

NIST SP 800-53 Rev 5 control SC-22 (Architecture and Provisioning for Name/Address Resolution Service) summarizes the requirements for this control: SC-22 · Architecture and Provisioning for Name/Address Resolution Service Control Statement: Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external role separation. Supplemental Guidance: Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external role separation. Systems that provide name and address resolu

NIST SP 800-53 Rev 5 control SC-15.1 (Physical or Logical Disconnect) summarizes the requirements for this control: SC-15.1 · Physical or Logical Disconnect Control Statement: Provide [organization-defined parameter] disconnect of collaborative computing devices in a manner that supports ease of use. Supplemental Guidance: Provide [organization-defined parameter] disconnect of collaborative computing devices in a manner that supports ease of use. Failing to disconnect from collaborative computing devices can result in subsequent compromises of organizational information. Providing easy methods to disconnect

NIST SP 800-171 Rev 3 control 03.13.08 (03.13.08 Transmission and Storage Confidentiality) requires organizations to implement the following: 03.13.08 · Transmission and Storage Confidentiality

Supplemental Guidance: This requirement applies to internal and external networks and any system components that can transmit CUI, including servers, notebook computers, desktop computers, mobile devices, printers, copiers, scanners, facsimile machines, and radios. Unprotected communication paths are susceptible to interception and modification. Encryption protects CUI from unauthorized disclosure during transmission and while in storage. Crypt For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.08.

NIST SP 800-171 Rev 3 control 03.13.08 (03.13.08 Transmission and Storage Confidentiality) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

SC-7.15 · Networked Privileged Accesses Control Statement: Route networked, privileged accesses through a dedicated, managed interface for purposes of access control and auditing. Supplemental Guidance: Route networked, privileged accesses through a dedicated, managed interface for purposes of access control and auditing. Privileged access provides greater accessibility to system functions, including security functions. Adversaries attempt to gain privileged access to systems through remote access to cause adverse mission or business impacts, such as by exfiltrating information or bringing down a critical system capability. Routing networked, privileged access requests through a dedicated, managed interface further restricts privileged access for increased access control and auditing.

Under the FedRAMP Moderate baseline, SC-10 (SC-10 Network Disconnect): FedRAMP Moderate Baseline · SC-10 · Network Disconnect Control Statement: Terminate the network connection associated with a communications session at the end of the session or after [organization-defined parameter] of inactivity. Supplemental Guidance: Terminate the network connection associated with a communications session at the end of the session or after [organization-defined parameter] of inactivity. Network disconnect applies to internal and external networks. Terminating network connections

NIST SP 800-53 Rev 5 control SC-7.29 (Separate Subnets to Isolate Functions) summarizes the requirements for this control: SC-7.29 · Separate Subnets to Isolate Functions Control Statement: Implement [organization-defined parameter] separate subnetworks to isolate the following critical system components and functions: [organization-defined parameter]. Supplemental Guidance: Implement [organization-defined parameter] separate subnetworks to isolate the following critical system components and functions: [organization-defined parameter]. Separating critical system components and functions from other noncritical systems

NIST SP 800-53 Rev 5 control SC-3.4 (Module Coupling and Cohesiveness) is assessed by examining, interviewing, and testing: SC-3.4 · Module Coupling and Cohesiveness Control Statement: Implement security functions as largely independent modules that maximize internal cohesiveness within modules and minimize coupling between modules. Supplemental Guidance: Implement security functions as largely independent modules that maximize internal cohesiveness within modules and minimize coupling between modules. The reduction of inter-module interactions helps to constrain security functions and manage complexity. The concept

NIST SP 800-171 Rev 3 control 03.13.08 (03.13.08 Transmission and Storage Confidentiality) falls under the System and Communications Protection family. 03.13.08 · Transmission and Storage Confidentiality Supplemental Guidance: This requirement applies to internal and external networks and any system components that can transmit CUI, including servers, notebook computers, desktop computers, mobile devices, printers, copiers, scanners, facsimile machines, and radios. Unprotected communication paths are susceptible to interception and modification. Encryption protects CUI from unauthorized disclosure during transmission and while in storage. Crypt Supplemental Guidance: This requirement applies to internal and external networks and any system components that can transmit CUI, including servers, notebook computers, desktop computers, mobile devices, printers, copiers, scanners, facsimile machines, and radios. Unprotected communication paths are susceptible to interception and modification. Encryption protects CUI from unauthorized disclosure during transmission and while in storage. Cryptographic mechanisms that protect the confidentiality

NIST SP 800-53 Rev 5 control SC-8 (Transmission Confidentiality and Integrity) summarizes the requirements for this control: SC-8 · Transmission Confidentiality and Integrity Control Statement: Protect the [organization-defined parameter] of transmitted information. Supplemental Guidance: Protect the [organization-defined parameter] of transmitted information. Protecting the confidentiality and integrity of transmitted information applies to internal and external networks as well as any system components that can transmit information, including servers, notebook computers, desktop computers, mobile devices, printers

NIST SP 800-53 Rev 5 control SC-40.2 (Reduce Detection Potential) summarizes the requirements for this control: SC-40.2 · Reduce Detection Potential Control Statement: Implement cryptographic mechanisms to reduce the detection potential of wireless links to [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to reduce the detection potential of wireless links to [organization-defined parameter]. The implementation of cryptographic mechanisms to reduce detection potential is used for covert communications and to protect wireless transmitters from geo-location. It a

NIST SP 800-53 Rev 5 control SC-3 (Security Function Isolation) summarizes the requirements for this control: SC-3 · Security Function Isolation Control Statement: Isolate security functions from nonsecurity functions. Supplemental Guidance: Isolate security functions from nonsecurity functions. Security functions are isolated from nonsecurity functions by means of an isolation boundary implemented within a system via partitions and domains. The isolation boundary controls access to and protects the integrity of the hardware, software, and firmware that perform system security functions. Systems imple

) For NIST SP 800-171 R2 basic and derived security requirements that, if not implemented, could lead to significant exploitation of the network, or exfiltration of CUI, five (5) points are subtracted from the maximum score. The basic and derived security requirements with a value of five (5) points include: (i) Basic security requirements. AC.L2-3.1.1, AC.L2-3.1.2, AT.L2-3.2.1, AT.L2-3.2.2, AU.L2-3.3.1, CM.L2-3.4.1, CM.L2-3.4.2, IA.L2-3.5.1, IA.L2-3.5.2, IR.L2-3.6.1, IR.L2-3.6.2, MA.L2-3.7.2, MP.L2-3.8.3, PS.L2-3.9.2, PE.L2-3.10.1, PE.L2-3.10.2, CA.L2-3.12.1, CA.L2-3.12.3, SC.L2-3.13.1, SC.L2-3.13.2, SI.L2-3.14.1, SI.L2-3.14.2, and SI.L2-3.14.3. (ii) Derived security requirements. AC.L2-3.1.12, AC.L2-3.1.13, AC.L2-3.1.16, AC.L2-3.1.17, AC.L2-3.1.18, AU.L2-3.3.5, CM.L2-3.4.5, CM.L2-3.4.6, CM.L2-3.4.7, CM.L2-3.4.8, IA.L2-3.5.10, MA.L2-3.7.5, MP.L2-3.8.7, RA.L2-3.11.2, SC.L2-3.13.5, SC.L2-3.13.6, SC.L2-3.13.15, SI.L2-3.14.4, and SI.L2-3.14.6. (2) For basic and derived security requirements that, if not implemented, have a specific and confined effect on the security of the network and its data, three (3) points are subtracted from the maximum score. The basic and derived security requirements with a value of three (3) points include: (i) Basic security requirements. AU.L2-3.3.2, MA.L2-3.7.1, MP.L2-3.8.1, MP.L2-3.8.2, PS.L2-3.9.1, RA.L2-3.11.1, and CA.L2-3.12.2. (ii) Derived security requirements. AC.L2-3.1.5, AC.L2-3.1.19, MA.L2-3.7.4, MP.L2-3.8.8, SC.L2-3.13.8, SI.L2-3.14.5, and SI.L2-3.14.7. (3) All remaining derived security requirements, other than the exceptions noted, if not implemented, have a limited or indirect effect on the security of the network and its data. For these, 1 point is subtracted from the maximum score. (4) Two derived security requirements, IA.L2-3.5.3 and SC.L2-3.13.11, can be partially effective even if not completely or properly implemented, and the points deducted may be adjusted depending on how the security requirement is implemented. (i) Multi-factor authentication (MFA) (CMMC Level 2 security requirement IA.L2-3.5.3) is typically implemented first for remote and privileged users (since these users are both limited in number and more critical) and then for the general user, so three (3) points are subtracted from the maximum score if MFA is implemented only for remote and privileged users. Five (5) points are subtracted from the maximum score if MFA is not implemented for any users. (ii) FIPS-validated encryption (CMMC Level 2 security requirement SC.L2-3.13.11) is required to protect the confidentiality of CUI. If encryption is employed, but is not FIPS-validated, three (3) points are subtracted from the maximum score; if encryption is not (printed page 83237) employed; five (5) points are subtracted from the maximum score. (5

NIST SP 800-53 Rev 5 control SC-7.24 (Personally Identifiable Information) is assessed by examining, interviewing, and testing: SC-7.24 · Personally Identifiable Information Control Statement: For systems that process personally identifiable information: (a) Apply the following processing rules to data elements of personally identifiable information: [organization-defined parameter]; (b) Monitor for permitted processing at the external interfaces to the system and at key internal

boundaries within the system; (c) Document each processing exception; and (d) Review and remove exceptions that are no longer supported. Supp

NIST SP 800-171 Rev 3 control 03.13.13 (03.13.13 Mobile Code) falls under the System and Communications Protection family. Control Statement: SR-03.13.13.a Define acceptable mobile code and mobile code technologies. SR-03.13.13.b Authorize, monitor, and control the use of mobile code. Supplemental Guidance: Mobile code includes software programs or parts of programs that are obtained from remote systems, transmitted across a network, and executed on a local system without explicit installation or execution by the recipient. Decisions regarding the use of mobile code are based on the potential for the code to cause damage to the system if used maliciously. Mobile code technologies include Java applets, JavaScript, HTML5, VBScript, and WebGL. Usage restrictions and implementati

NIST SP 800-171 Rev 3 control 03.13.06 (03.13.06 Network Communications · Deny by Default · Allow by Exception) is assessed by examining the following: Assessment Objectives: - network communications traffic is denied by default. - network communications traffic is allowed by exception.

NIST SP 800-53 Rev 5 control SC-30.5 (Concealment of System Components) summarizes the requirements for this control: SC-30.5 · Concealment of System Components Control Statement: Employ the following techniques to hide or conceal [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Employ the following techniques to hide or conceal [organization-defined parameter]: [organization-defined parameter]. By hiding, disguising, or concealing critical system components, organizations may be able to decrease the probability that adversaries target and successfully compromise thos

NIST SP 800-53 Rev 5 control SC-7.24 (Personally Identifiable Information) summarizes the requirements for this control: SC-7.24 · Personally Identifiable Information Control Statement: For systems that process personally identifiable information: (a) Apply the following processing rules to data elements of personally identifiable information: [organization-defined parameter]; (b) Monitor for permitted processing at the external interfaces to the system and at key internal boundaries within the system; (c) Document each processing exception; and (d) Review and remove exceptions that are no longer supported. Supp

NIST SP 800-53 Rev 5 control SC-7.10 (Prevent Exfiltration): SC-7.10 · Prevent Exfiltration Control Statement: (a) Prevent the exfiltration of information; and (b) Conduct exfiltration tests [organization-defined parameter]. Supplemental Guidance: (a) Prevent the exfiltration of information; and (b) Conduct exfiltration tests [organization-defined parameter]. Prevention of exfiltration applies to both the intentional and unintentional exfiltration of info

SC-40.3 · Imitative or Manipulative Communications Deception Control Statement: Implement cryptographic mechanisms to identify and reject wireless transmissions that are deliberate attempts to achieve imitative or manipulative communications deception based on signal parameters. Supplemental Guidance: Implement cryptographic mechanisms to identify and reject wireless transmissions that are deliberate attempts to achieve imitative or manipulative communications deception based on signal parameters. The implementation of cryptographic mechanisms to identify and reject imitative or manipulative communications ensures that the signal parameters of wireless transmissions are not predictable by unauthorized individuals. Such unpredictability reduces the probability of imitative or manipulative communications deception based on signal parameters alone.

Under the FedRAMP Moderate baseline, SC-7.7 (SC-7.7 Split Tunneling for Remote Devices): FedRAMP Moderate Baseline · SC-7.7 · Split Tunneling for Remote Devices Control Statement: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [organization-defined parameter]. Supplemental Guidance: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [organization-defined parameter]. Split tunneling is the process of allowing a rem

An OSA is only permitted to achieve the CMMC Status of Conditional Level 2 (Self) or Conditional Level 2 (C3PAO), as appropriate, if all the following conditions are met: (printed page 83235)
(i) The assessment score divided by the total number of CMMC Level 2 security requirements is

greater than or equal to 0.8; (ii) None of the security requirements included in the POA&M have a point value of greater than 1 as specified in the CMMC Scoring Methodology set forth in § 170.24, except SC.L2-3.13.11 CUI Encryption may be included on a POA&M if encryption is employed but it is not FIPS-validated, which would result in a point value of 3; and (iii) None of the following security requirements are included in the POA&M: (A) AC.L2-3.1.20 External Connections (CUI Data). (B) AC.L2-3.1.22 Control Public Information (CUI Data). (C) CA.L2-3.12.4 System Security Plan. (D) PE.L2-3.10.3 Escort Visitors (CUI Data). (E) PE.L2-3.10.4 Physical Access Logs (CUI Data). (F) PE.L2-3.10.5 Manage Physical Access (CUI Data). (3) Level 3 certification assessment. An OSC is only permitted to achieve the CMMC Status of Conditional Level 3 (DIBCAC) if all the following conditions are met: (i) The assessment score divided by the total number of CMMC Level 3 security requirements is greater than or equal to 0.8; and (ii) The POA&M does not include any of following security requirements: (A) IR.L3-3.6.1e Security Operations Center. (B) IR.L3-3.6.2e Cyber Incident Response Team. (C) RA.L3-3.11.1e Threat-Informed Risk Assessment. (D) RA.L3-3.11.6e Supply Chain Risk Response. (E) RA.L3-3.11.7e Supply Chain Risk Plan. (F) RA.L3-3.11.4e Security Solution Rationale. (G) SI.L3-3.14.3e Specialized Asset Security. (b) POA&M closeout assessment. A POA&M closeout assessment is a CMMC assessment that assesses only the NOT MET requirements that were identified with POA&M in the initial assessment. The closing of a POA&M must be confirmed by a POA&M closeout assessment within 180-days of the Conditional CMMC Status Date. If the POA&M is not successfully closed out within the 180-day timeframe, the Conditional CMMC Status for the information system will expire. (1) Level 2 self-assessment. For a Level 2 self-assessment, the POA&M closeout self-assessment shall be performed by the OSA in the same manner as the initial self-assessment. (2) Level 2 certification assessment. For Level 2 certification assessment, the POA&M closeout certification assessment must be performed by an authorized or accredited C3PAO. (3) Level 3 certification assessment. For Level 3 certification assessment, DCMA DIBCAC will perform the POA&M closeout certification assessment. § 170.22 Affirmation. (a) General.

SC-7.13 · Isolation of Security Tools, Mechanisms, and Support Components Control Statement: Isolate [organization-defined parameter] from other internal system components by implementing physically separate subnetworks with managed interfaces to other components of the system. Supplemental Guidance: Isolate [organization-defined parameter] from other internal system components by implementing physically separate subnetworks with managed interfaces to other components of the system. Physically separate subnetworks with managed interfaces are useful in isolating computer network defenses from critical operational processing networks to prevent adversaries from discovering the analysis and forensics techniques employed by organizations.

NIST SP 800-53 Rev 5 control SC-12.1 (Availability) is defined as follows: SC-12.1 · Availability Control Statement: Maintain availability of information in the event of the loss of cryptographic keys by users. Supplemental Guidance: Maintain availability of information in the event of the loss of cryptographic keys by users. Escrowing of encryption keys is a common practice for ensuring availability in the event of key loss. A forgotten passphrase is an example of losing a cryptographic key.

NIST SP 800-53 Rev 5 control SC-25 (Thin Nodes) summarizes the requirements for this control: SC-25 · Thin Nodes Control Statement: Employ minimal functionality and information storage on the following system components: [organization-defined parameter]. Supplemental Guidance: Employ minimal functionality and information storage on the following system components: [organization-defined parameter]. The deployment of system components with minimal functionality reduces the need to secure every endpoint and may reduce the exposure of information, systems, and services to attacks. Reduced

From the NIST SP 800-172 Rev 3 Final Public Draft: The implementation of concealment and 1808 misdirection techniques may add to the complexity and management overhead required for the system. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. P ROTECTION STRATEGY PRA, CRS ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Redirect (Deceive) REFERENCES Source Control: SC-30 03.1 3.04E Isolation of System Components Employ boundary protection mechanisms to isolate [Assignment: organization-defined system components]. DISCUSSION Organizations can isolate system components that perform different mission or business functions. Isolating system components with boundary protection mechanisms provide

NIST SP 800-53 Rev 5 control SC-40.1 (Electromagnetic Interference) summarizes the requirements for this control: SC-40.1 · Electromagnetic Interference Control Statement: Implement cryptographic mechanisms that achieve [organization-defined parameter] against the effects of intentional electromagnetic interference. Supplemental Guidance: Implement cryptographic mechanisms that achieve [organization-defined parameter] against the effects of intentional electromagnetic interference. The implementation of cryptographic mechanisms for electromagnetic interference protects systems against intentional jamming

NIST SP 800-53 Rev 5 control SC-20 (Secure Name/Address Resolution Service (Authoritative Source)) summarizes the requirements for this control: SC-20 · Secure Name/Address Resolution Service (Authoritative Source) Control Statement: a. Provide additional data origin authentication and integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name/address resolution queries; and b. Provide the means to indicate the security status of child zones and (if the child supports secure resolution services) to enable verification of a chain of trust among parent and child domains

NIST SP 800-53 Rev 5 control SC-7.10 (Prevent Exfiltration) is assessed by examining, interviewing, and testing: SC-7.10 · Prevent Exfiltration Control Statement: (a) Prevent the exfiltration of information; and (b) Conduct exfiltration tests [organization-defined parameter]. Supplemental Guidance: (a) Prevent the exfiltration of information; and (b) Conduct exfiltration tests [organization-defined parameter]. Prevention of exfiltration applies to both the intentional and unintentional exfiltration of information. Techniques used to prevent the exfiltration of information from systems may be implemented

NIST SP 800-53 Rev 5 control SC-38 (Operations Security) is defined as follows: SC-38 · Operations Security Control Statement: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defined parameter]. Supplemental Guidance: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defined parameter]. Operations security (OPSEC) is a systematic process by which potential adversaries can be denied information about the capabilities and intentions of organizations by identifying, controlling, and protecting generally unclassified information that specifically relates to the planning and execution of sensitive organizational activities. The OPSEC process involves five steps: identification of critical information, analysis of threats, analysis of vulnerabilities, assessment of risks, and the application of appropriate countermeasures. OPSEC controls are CHAPTER THREE PAGE 323 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>

Control SC-38: OPERATIONS SECURITY Control: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [Assignment: organization-defined operations security controls]. Discussion: Operations security (OPSEC) is a systematic process by which potential adversaries can be denied information about the capabilities and intentions of organizations by identifying, controlling, and protecting generally unclassified information that specifically relates to the planning and execution of sensitive organizational activities. The OPSEC process involves five steps: identification of critical information, analysis of threats, analysis of vulnerabilities, assessment of risks, and the application of appropriate countermeasures. OPSEC controls are CHAPTER THREE PAGE 323 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

applied to organizational systems and the environments in which those systems operate. OPSEC controls protect the confidentiality of information, including limiting the sharing of information with suppliers, potential suppliers, and other non-organizational elements and individuals. Information critical to organizational mission and business functions includes user identities, element uses, suppliers, supply chain processes, functional requirements, security requirements, system design specifications, testing and evaluation protocols, and security control implementation details. Related Controls: CA-2, CA-7, PL-1, PM-9, PM-12, RA-2, RA-3, RA-5, SC-7, SR-3, SR-7. Control Enhancements: None.

Under the FedRAMP Low baseline, SC-20 (SC-20 Secure Name/Address Resolution Service (Authoritative Source)): FedRAMP Low Baseline · SC-20 · Secure Name/Address Resolution Service (Authoritative Source) Control Statement: a. Provide additional data origin authentication and integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name/address resolution queries; and b. Provide the means to indicate the security status of child zones and (if the child supports secure resolution services) to enable

verification of a chain of trust among

SC-23.5 · Allowed Certificate Authorities Control Statement: Only allow the use of [organization-defined parameter] for verification of the establishment of protected sessions. Supplemental Guidance: Only allow the use of [organization-defined parameter] for verification of the establishment of protected sessions. Reliance on certificate authorities for the establishment of secure sessions includes the use of Transport Layer Security (TLS) certificates. These certificates, after verification by their respective certificate authorities, facilitate the establishment of protected sessions between web clients and web servers.

NIST SP 800-53 Rev 5 control SC-35 (External Malicious Code Identification) summarizes the requirements for this control: SC-35 · External Malicious Code Identification Control Statement: Include system components that proactively seek to identify network-based malicious code or malicious websites. Supplemental Guidance: Include system components that proactively seek to identify network-based malicious code or malicious websites. External malicious code identification differs from decoys in [SC-26](#sc-26) in that the components actively probe networks, including the Internet, in search of malicious code contain

NIST SP 800-53 Rev 5 control SC-7.20 (Dynamic Isolation and Segregation) summarizes the requirements for this control: SC-7.20 · Dynamic Isolation and Segregation Control Statement: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. Supplemental Guidance: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. The capability to dynamically isolate certain internal system components is useful when it is necessary to partition or separate system components of questionable origin from components that pos

03.13.08 · Transmission and Storage Confidentiality Supplemental Guidance: This requirement applies to internal and external networks and any system components that can transmit CUI, including servers, notebook computers, desktop computers, mobile devices, printers, copiers, scanners, facsimile machines, and radios. Unprotected communication paths are susceptible to interception and modification. Encryption protects CUI from unauthorized disclosure during transmission and while in storage. Cryptographic mechanisms that protect the confidentiality of CUI during transmission include TLS and IPsec. Information in storage (i.e., information at rest) refers to the state of CUI when it is not in process or in transit and resides on internal or external storage devices, storage area network devices, and databases. Protecting CUI in storage does not focus on the type of storage device or the frequency of access to that device but rather on the state of the information. This requirement relates to [(#cprt/framework/version/SP_800_171_3_0_0/home?element=03.13.11) 03.13.11. Assessment Objectives: - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI during transmission. - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI while in storage.

NIST SP 800-171 Rev 3 control 03.13.11 (03.13.11 Cryptographic Protection) is assessed by examining the following: Assessment Objectives: - the following types of cryptography are implemented to protect the confidentiality of CUI: [organization-defined parameter].

NIST SP 800-53 Rev 5 control SC-36.2 (Synchronization) summarizes the requirements for this control: SC-36.2 · Synchronization Control Statement: Synchronize the following duplicate systems or system components: [organization-defined parameter]. Supplemental Guidance: Synchronize the following duplicate systems or system components: [organization-defined parameter]. [SC-36](#sc-36) and [CP-9(6)](#cp-9.6) require the duplication of systems or system components in distributed locations. The synchronization of duplicated and redundant services and data helps to ensure that information contained

NIST SP 800-53 Rev 5 control SC-29.1 (Virtualization Techniques) summarizes the requirements for this control: SC-29.1 · Virtualization Techniques Control Statement: Employ virtualization techniques to support the deployment of a diversity of operating systems and applications that are changed [organization-defined parameter]. Supplemental Guidance: Employ virtualization techniques to support the deployment of a diversity of operating systems and applications that are changed [organization-defined parameter]. While frequent changes to operating systems and applications can pose significant configuratio

NIST SP 800-53 Rev 5 control SC-7.20 (Dynamic Isolation and Segregation) is defined as follows:
SC-7.20 · Dynamic Isolation and Segregation Control Statement: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. Supplemental Guidance: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. The capability to dynamically isolate certain internal system components is useful when it is necessary to partition or separate system components of questionable origin from components that possess greater trustworthiness. Component isolation reduces the attack surface of organizational systems.

Under the FedRAMP High baseline, SC-7.12 (SC-7.12 Host-based Protection): FedRAMP High Baseline · SC-7.12 · Host-based Protection Control Statement: Implement [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Implement [organization-defined parameter] at [organization-defined parameter]. Host-based boundary protection mechanisms include host-based firewalls. System components that employ host-based boundary protection mechanisms include servers, workstations, notebook computers, and mobile devices. Assessment Objectives: I

NIST SP 800-53 Rev 5 control SC-8.1 (Cryptographic Protection) is assessed by examining, interviewing, and testing: SC-8.1 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to [organization-defined parameter] during transmission. Supplemental Guidance: Implement cryptographic mechanisms to [organization-defined parameter] during transmission. Encryption protects information from unauthorized disclosure and modification during transmission. Cryptographic mechanisms that protect the confidentiality and integrity of information during transmission include TLS and IPsec. Cryptogra

NIST SP 800-53 Rev 5 control SC-28.3 (Cryptographic Keys) is assessed by examining, interviewing, and testing: SC-28.3 · Cryptographic Keys Control Statement: Provide protected storage for cryptographic keys [organization-defined parameter]. Supplemental Guidance: Provide protected storage for cryptographic keys [organization-defined parameter]. A Trusted Platform Module (TPM) is an example of a hardware-protected data store that can be used to protect cryptographic keys.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY DLO, CRS NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 ADVERSARY EFFECTS 401 Expose (Detect), Limit (Reduce) REFERENCES Source Control: SC-26 2.3. Enhanced Security Requirement Selection Organizations18 18 The term 'organization' is context-dependent. For example, in an enhanced security requirement with an ODP, organization can refer to the federal agency or the nonfederal organization that establishes the parameter values for the requirement. can select the enhanced security requirements either comprehensively or selectively as part of their overarching risk management strategy. However, there are dependencies among certain requirements that may affect the selection process. The decision to

Under the FedRAMP Moderate baseline, SC-4 (SC-4 Information in Shared System Resources): FedRAMP Moderate Baseline · SC-4 · Information in Shared System Resources Control Statement: Prevent unauthorized and unintended information transfer via shared system resources. Supplemental Guidance: Prevent unauthorized and unintended information transfer via shared system resources. Preventing unauthorized and unintended information transfer via shared system resources stops information produced by the actions of prior users or roles (or the actions of processes acting on behalf of prior u

NIST SP 800-53 Rev 5 control SC-5.3 (Detection and Monitoring) is assessed by examining, interviewing, and testing: SC-5.3 · Detection and Monitoring Control Statement: (a) Employ the following monitoring tools to detect indicators of denial-of-service attacks against, or launched from, the system: [organization-defined parameter] ; and (b) Monitor the following system resources to determine if sufficient resources exist to prevent effective denial-of-service attacks: [organization-defined parameter]. Supplemental Guidance: (a) Employ the following monitoring tools to detect indicators of denial-of-service

NIST SP 800-53 Rev 5 control SC-34 (Non-modifiable Executable Programs) is assessed by examining, interviewing, and testing: SC-34 · Non-modifiable Executable Programs Control Statement: For [organization-defined parameter] , load and execute: a. The operating environment from hardware-

enforced, read-only media; and b. The following applications from hardware-enforced, read-only media: [organization-defined parameter]. Supplemental Guidance: For [organization-defined parameter], load and execute: a. The operating environment from hardware-enforced, read-only media; and b. The following applications from hardware-en

NIST SP 800-171 Rev 3 control 03.13.01 (03.13.01 Boundary Protection) is assessed by examining the following: Assessment Objectives: - communications at external managed interfaces to the system are monitored. - communications at external managed interfaces to the system are controlled. - communications at key internal managed interfaces within the system are monitored. - communications at key internal managed interfaces within the system are controlled. - subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks. - external system connections are only made through managed interfaces that consist of boundary protection device

Control SC-24: FAIL IN KNOWN STATE Control: Fail to a [Assignment: organization-defined known system state] for the following failures on the indicated components while preserving [Assignment: organization-defined system state information] in failure: [Assignment: list of organization-defined types of system failures on organization-defined system components]. Discussion: Failure in a known state addresses security concerns in accordance with the mission and business needs of organizations. Failure in a known state prevents the loss of confidentiality, integrity, or availability of information in the event of failures of organizational systems or system components. Failure in a known safe state helps to prevent systems from failing to a state that may cause injury to individuals or destruction to property. Preserving system state information facilitates system restart and return to the operational mode with less disruption of mission and business processes. Related Controls: CP-2, CP-4, CP-10, CP-12, SA-8, SC-7, SC-22, SI-13. Control Enhancements: None. References: None.

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: System and Communications Protection 3.13.9 Termination of Network Connections Terminate the network connection associated with a communications session at the end of the session or after [Assignment: organization-defined time period] (03.13.09) of inactivity. Related Controls: SC-10 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.13.09 [Assignment: organization-defined time period] no longer than 15 minutes System and Communications Protection 3.13.10 Cryptographic Key Management Establish and manage cryptographic keys in the system in accordance with the following key management requirements: [Assignment: organization-defined requirements for key generation, distribution, storage, access, and destruction] (03.13.10). Related Controls: SC-12 ODP Values ODP I

NIST SP 800-53 Rev 5 control SC-12 (Cryptographic Key Establishment and Management) is defined as follows: SC-12 · Cryptographic Key Establishment and Management Control Statement: Establish and manage cryptographic keys when cryptography is employed within the system in accordance with the following key management requirements: [organization-defined parameter]. Supplemental Guidance: Establish and manage cryptographic keys when cryptography is employed within the system in accordance with the following key management requirements: [organization-defined parameter]. Cryptographic key management and establishment can be performed using manual procedures or automated mechanisms with supporting manua

SC-7.20 · Dynamic Isolation and Segregation Control Statement: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. Supplemental Guidance: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. The capability to dynamically isolate certain internal system components is useful when it is necessary to partition or separate system components of questionable origin from components that possess greater trustworthiness. Component isolation reduces the attack surface of organizational systems. Isolating selected system components can also limit the damage from successful attacks when such attacks occur.

NIST SP 800-171 Rev 3 control 03.13.10 (03.13.10 Cryptographic Key Establishment and Management) falls under the System and Communications Protection family. 03.13.10 · Cryptographic Key Establishment and Management Supplemental Guidance: Cryptographic keys can be established and managed using either manual procedures or automated mechanisms supported by manual procedures. Organizations satisfy key establishment and management requirements in accordance with applicable

federal laws, Executive Orders, policies, directives, regulations, and standards that specify appropriate options, levels, and parameters. This requirement is related to [link] (#/cppt/fra
Supplemental Guidance: Cryptographic keys can be established and managed using either manual procedures or automated mechanisms supported by manual procedures. Organizations satisfy key establishment and management requirements in accordance with applicable federal laws, Executive Orders, policies, directives, regulations, and standards that specify appropriate options, levels, and parameters. This requirement is related to [link] (#/cppt/framework/version/SP_800_171_3_0_0/home?element=03.13.11) 03.1

Under the FedRAMP High baseline, SC-12 (SC-12 Cryptographic Key Establishment and Management):
FedRAMP High Baseline · SC-12 · Cryptographic Key Establishment and Management Control Statement: Establish and manage cryptographic keys when cryptography is employed within the system in accordance with the following key management requirements: [organization-defined parameter].
Supplemental Guidance: Establish and manage cryptographic keys when cryptography is employed within the system in accordance with the following key management requirements: [organization-defined parameter]. Cryptogra

SC-36 · Distributed Processing and Storage Control Statement: Distribute the following processing and storage components across multiple [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Distribute the following processing and storage components across multiple [organization-defined parameter]: [organization-defined parameter]. Distributing processing and storage across multiple physical locations or logical domains provides a degree of redundancy or overlap for organizations. The redundancy and overlap increase the work factor of adversaries to adversely impact organizational operations, assets, and individuals. The use of distributed processing and storage does not assume a single primary processing or storage location. Therefore, it allows for parallel processing and storage.

NIST SP 800-171 Rev 3 control 03.13.09 (03.13.09 Network Disconnect) is assessed by examining the following: Assessment Objectives: - the network connection associated with a communications session is terminated at the end of the session or after [organization-defined parameter] of inactivity.

NIST SP 800-53 Rev 5 control SC-7.15 (Networked Privileged Accesses) is defined as follows: SC-7.15 · Networked Privileged Accesses Control Statement: Route networked, privileged accesses through a dedicated, managed interface for purposes of access control and auditing. Supplemental Guidance: Route networked, privileged accesses through a dedicated, managed interface for purposes of access control and auditing. Privileged access provides greater accessibility to system functions, including security functions. Adversaries attempt to gain privileged access to systems through remote access to cause adverse mission or business impacts, such as by exfiltrating information or bringing d

and (d) Review and remove exceptions that are no longer supported. Discussion: Managing the processing of personally identifiable information is an important aspect of protecting an individual's privacy. Applying, monitoring for, and documenting exceptions to processing rules ensure that personally identifiable information is processed only in accordance with established privacy requirements. Related Controls: PT-2, SI-15. (25) BOUNDARY PROTECTION | UNCLASSIFIED NATIONAL SECURITY SYSTEM CONNECTIONS Prohibit the direct connection of [Assignment: organization-defined unclassified national security system] to an external network without the use of [Assignment: organization-defined boundary protection device]. Discussion: A direct connection is a dedicated physical or virtual connection between two or more systems. Organizations typically do not have complete control over external networks, including the Internet.

NIST SP 800-53 Rev 5 control SC-7.27 (Unclassified Non-national Security System Connections) summarizes the requirements for this control: SC-7.27 · Unclassified Non-national Security System Connections Control Statement: Prohibit the direct connection of [organization-defined parameter] to an external network without the use of [organization-defined parameter]. Supplemental Guidance: Prohibit the direct connection of [organization-defined parameter] to an external network without the use of [organization-defined parameter]. A direct connection is a dedicated physical or virtual connection between two or more systems. Organizatio

NIST SP 800-53 Rev 5 control SC-16.3 (Cryptographic Binding) summarizes the requirements for this

control: SC-16.3 · Cryptographic Binding Control Statement: Implement [organization-defined parameter] to bind security and privacy attributes to transmitted information. Supplemental Guidance: Implement [organization-defined parameter] to bind security and privacy attributes to transmitted information. Cryptographic mechanisms and techniques can provide strong security and privacy attribute binding to transmitted information to help ensure the integrity of such information.

NIST SP 800-53 Rev 5 control SC-2.1 (Interfaces for Non-privileged Users) is assessed by examining, interviewing, and testing: SC-2.1 · Interfaces for Non-privileged Users Control Statement: Prevent the presentation of system management functionality at interfaces to non-privileged users. Supplemental Guidance: Prevent the presentation of system management functionality at interfaces to non-privileged users. Preventing the presentation of system management functionality at interfaces to non-privileged users ensures that system administration options, including administrator privileges, are not available to the general

Under the FedRAMP High baseline, SC-7.4 (SC-7.4 External Telecommunications Services): FedRAMP High Baseline · SC-7.4 · External Telecommunications Services Control Statement: (a) Implement a managed interface for each external telecommunication service; (b) Establish a traffic flow policy for each managed interface; (c) Protect the confidentiality and integrity of the information being transmitted across each interface; (d) Document each exception to the traffic flow policy with a supporting mission or business need and duration of that need; (e) Review exceptions to the traffic

NIST SP 800-53 Rev 5 control SC-40.4 (Signal Parameter Identification) summarizes the requirements for this control: SC-40.4 · Signal Parameter Identification Control Statement: Implement cryptographic mechanisms to prevent the identification of [organization-defined parameter] by using the transmitter signal parameters. Supplemental Guidance: Implement cryptographic mechanisms to prevent the identification of [organization-defined parameter] by using the transmitter signal parameters. The implementation of cryptographic mechanisms to prevent the identification of wireless transmitters protects against the u

Control SC-1: | | [COBIT] | Information Systems Audit and Control Association (ISACA) (2021) Control Objectives for Information and Related Technologies . Available at <https://www.isaca.org/resources/cobit> | | [IEA] | International Energy Agency (2021) Enhancing Cyber Resilience in Electricity Systems . Available at | | [ISA] | International Society of Automation (2013) ISA 62443-3-3:2013 - Security for industrial automation and control systems Part 3-3: System security requirements and security levels (ISA, North Carolina, USA). Available at <https://www.isa.org/products/ansi-isa-62443-3-3-99-03-03-2013-security-for-indu> | | [ISO] | International Organization for Standardization/International Electrotechnical Commission (2013) ISO/IEC 27001:2013 - Information technology - Security techniques - Information security management systems - Requirements (ISO, Geneva, Switzerland). Available at <https://www.iso.org/standard/54534.html> | | [Mapping] | National Institute of Standards and Technology and North American Electric Reliability Corporation (2020) Mapping of NIST Cybersecurity Framework v1.1 to NERC CIP Reliability Standards . <https://doi.org/10.18434/mds2-2348> | | [NERC CIP] | North American Electric Reliability Corporation (2021) NERC CIP Enforceable Standards .

NIST SP 800-53 Rev 5 control SC-8.3 (Cryptographic Protection for Message Externals) summarizes the requirements for this control: SC-8.3 · Cryptographic Protection for Message Externals Control Statement: Implement cryptographic mechanisms to protect message externals unless otherwise protected by [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to protect message externals unless otherwise protected by [organization-defined parameter]. Cryptographic protection for message externals addresses protection from the unauthorized disclosure of information. Message externals include m

NIST SP 800-53 Rev 5 control SC-25 (Thin Nodes) is assessed by examining, interviewing, and testing: SC-25 · Thin Nodes Control Statement: Employ minimal functionality and information storage on the following system components: [organization-defined parameter]. Supplemental Guidance: Employ minimal functionality and information storage on the following system components: [organization-defined parameter]. The deployment of system components with minimal functionality reduces the need to secure every endpoint and may reduce the exposure of information, systems, and services to attacks. Reduced

NIST SP 800-53 Rev 5 control SC-30 (Concealment and Misdirection) is defined as follows: SC-30 · Concealment and Misdirection Control Statement: Employ the following concealment and misdirection techniques for [organization-defined parameter] at [organization-defined parameter] to confuse and mislead adversaries: [organization-defined parameter]. Supplemental Guidance: Employ the following concealment and misdirection techniques for [organization-defined parameter] at [organization-defined parameter] to confuse and mislead adversaries: [organization-defined parameter]. Concealment and misdirection techniques can significantly reduce the targeting capabilities of adversaries (i.e

NIST SP 800-53 Rev 5 control SC-7.4 (External Telecommunications Services) is assessed by examining, interviewing, and testing: SC-7.4 · External Telecommunications Services Control Statement: (a) Implement a managed interface for each external telecommunication service; (b) Establish a traffic flow policy for each managed interface; (c) Protect the confidentiality and integrity of the information being transmitted across each interface; (d) Document each exception to the traffic flow policy with a supporting mission or business need and duration of that need; (e) Review exceptions to the traffic flow policy [organizati

NIST SP 800-53 Rev 5 control SC-28.2 (Offline Storage) summarizes the requirements for this control: SC-28.2 · Offline Storage Control Statement: Remove the following information from online storage and store offline in a secure location: [organization-defined parameter]. Supplemental Guidance: Remove the following information from online storage and store offline in a secure location: [organization-defined parameter]. Removing organizational information from online storage to offline storage eliminates the possibility of individuals gaining unauthorized access to the information through a ne

NIST SP 800-53 Rev 5 control SC-41 (Port and I/O Device Access): SC-41 · Port and I/O Device Access Control Statement: [organization-defined parameter] disable or remove [organization-defined parameter] on the following systems or system components: [organization-defined parameter]. Supplemental Guidance: [organization-defined parameter] disable or remove [organization-defined parameter] on the following systems or system components: [organization-defined par

NIST SP 800-53 Rev 5 control SC-6 (Resource Availability) summarizes the requirements for this control: SC-6 · Resource Availability Control Statement: Protect the availability of resources by allocating [organization-defined parameter] by [organization-defined parameter]. Supplemental Guidance: Protect the availability of resources by allocating [organization-defined parameter] by [organization-defined parameter]. Priority protection prevents lower-priority processes from delaying or interfering with the system that services higher-priority processes. Quotas prevent users or processes from obta

NIST SP 800-53 Rev 5 control SC-45.2 (Secondary Authoritative Time Source) summarizes the requirements for this control: SC-45.2 · Secondary Authoritative Time Source Control Statement: (a) Identify a secondary authoritative time source that is in a different geographic region than the primary authoritative time source; and (b) Synchronize the internal system clocks to the secondary authoritative time source if the primary authoritative time source is unavailable. Supplemental Guidance: (a) Identify a secondary authoritative time source that is in a different geographic region than the primary authoritative time

NIST SP 800-53 Rev 5 control SC-7.5 (Deny by Default · Allow by Exception) is assessed by examining, interviewing, and testing: SC-7.5 · Deny by Default · Allow by Exception Control Statement: Deny network communications traffic by default and allow network communications traffic by exception [organization-defined parameter]. Supplemental Guidance: Deny network communications traffic by default and allow network communications traffic by exception [organization-defined parameter]. Denying by default and allowing by exception applies to inbound and outbound network communications traffic. A deny-all, permit-by-exception

SC-11 · Trusted Path Control Statement: a. Provide a [organization-defined parameter] isolated trusted communications path for communications between the user and the trusted components of the system; and b. Permit users to invoke the trusted communications path for communications between the user and the following security functions of the system, including at a minimum, authentication and re-authentication: [organization-defined parameter]. Supplemental Guidance: a. Provide a

[organization-defined parameter] isolated trusted communications path for communications between the user and the trusted components of the system; and b. Permit users to invoke the trusted communications path for communications between the user and the following security functions of the system, including at a minimum, authentication and re-authentication: [organization-defined parameter]. Trusted paths are mechanisms by which users can communicate (using input devices such as keyboards) directly with the security functions of systems with the requisite assurance to support security policies. Trusted path mechanisms can only be activated by users or the security functions of organizational systems. User responses that occur via trusted paths are protected from modification by and disclosure to untrusted applications. Organizations employ trusted paths for trustworthy, high-assurance connections between security functions of systems and users, including during system logons. The original implementations of trusted paths employed an out-of-band signal to initiate the path, such as using the <BREAK> key, which does not transmit characters that can be spoofed. In later implementations, a key combination that could not be hijacked was used (e.g., the <CTRL> + <ALT> + keys). Such key combinations, however, are platform-specific and may not provide a trusted path implementation in every case. The enforcement of trusted communications paths is provided by a specific implementation that meets the reference monitor concept.

Implementing 03.13.13 (03.13.13 Mobile Code) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.13.13 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.13.13 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Under the FedRAMP Moderate baseline, SC-45.1 (SC-45.1 Synchronization with Authoritative Time Source): FedRAMP Moderate Baseline · SC-45.1 · Synchronization with Authoritative Time Source Control Statement: (a) Compare the internal system clocks [organization-defined parameter] with [organization-defined parameter] ; and (b) Synchronize the internal system clocks to the authoritative time source when the time difference is greater than [organization-defined parameter]. Supplemental Guidance: (a) Compare the internal system clocks [organization-defined parameter] with [organization-defined param

Under the FedRAMP Moderate baseline, SC-18 (SC-18 Mobile Code): FedRAMP Moderate Baseline · SC-18 · Mobile Code Control Statement: a. Define acceptable and unacceptable mobile code and mobile code technologies; and b. Authorize, monitor, and control the use of mobile code within the system. Supplemental Guidance: a. Define acceptable and unacceptable mobile code and mobile code technologies; and b. Authorize, monitor, and control the use of mobile code within the system. Mobile code includes any program, application, or content that can be transmitted acro

NIST SP 800-53 Rev 5 control SC-34.1 (No Writable Storage) summarizes the requirements for this control: SC-34.1 · No Writable Storage Control Statement: Employ [organization-defined parameter] with no writeable storage that is persistent across component restart or power on/off. Supplemental Guidance: Employ [organization-defined parameter] with no writeable storage that is persistent across component restart or power on/off. Disallowing writeable storage eliminates the possibility of malicious code insertion via persistent, writeable storage within the designated system components. The restrict

SC.L2-3.13.13 · Mobile Code CMMC Assessment Guide · Level 2 | Version 2.13 238 SC.L2-3.13.13 · MOBILE CODE Control and monitor the use of mobile code. ASSESSMENT OBJECTIVES [NIST SP 800-171A]211 Determine if: [a] use of mobile code is controlled; and [b] use of mobile code is monitored. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]211 Examine [SELECT FROM: System and communications protection policy; procedures addressing mobile code; mobile code usage restrictions, mobile code implementation policy and procedures; system audit logs and records; system security plan; list of acceptable mobile code and mobile code technologies; list of

unacceptable mobile code and mobile technologies; authorization records; system monitoring records; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: System or network administrators; personnel with information security responsibilities; personnel with responsibilities for managing mobile code]. Test [SELECT FROM: Organizational process for controlling, authorizing, monitoring, and restricting mobile code; mechanisms supporting or implementing the management of mobile code; mechanisms supporting or implementing the monitoring of mobile code]. DISCUSSION [NIST SP 800-171 REV. 2]

Under the FedRAMP Low baseline, SC-21 (SC-21 Secure Name/Address Resolution Service (Recursive or Caching Resolver)): FedRAMP Low Baseline · SC-21 · Secure Name/Address Resolution Service (Recursive or Caching Resolver) Control Statement: Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources. Supplemental Guidance: Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources. Each client of nam

NIST SP 800-53 Rev 5 control SC-22 (Architecture and Provisioning for Name/Address Resolution Service) is assessed by examining, interviewing, and testing: SC-22 · Architecture and Provisioning for Name/Address Resolution Service Control Statement: Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external role separation. Supplemental Guidance: Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external role separation. Systems that provide name and address resolu

NIST SP 800-53 Rev 5 control SC-38 (Operations Security) is assessed by examining, interviewing, and testing: SC-38 · Operations Security Control Statement: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defined parameter]. Supplemental Guidance: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defined parameter]. Operations security (OPSEC) is a systematic process by which potential adversaries c

NIST SP 800-53 Rev 5 control SC-7.22 (Separate Subnets for Connecting to Different Security Domains) summarizes the requirements for this control: SC-7.22 · Separate Subnets for Connecting to Different Security Domains Control Statement: Implement separate network addresses to connect to systems in different security domains. Supplemental Guidance: Implement separate network addresses to connect to systems in different security domains. The decomposition of systems into subnetworks (i.e., subnets) helps to provide the appropriate level of protection for network connections to different security domains that contain information with diffe

NIST SP 800-53 Rev 5 control SC-15.4 (Explicitly Indicate Current Participants) summarizes the requirements for this control: SC-15.4 · Explicitly Indicate Current Participants Control Statement: Provide an explicit indication of current participants in [organization-defined parameter]. Supplemental Guidance: Provide an explicit indication of current participants in [organization-defined parameter]. Explicitly indicating current participants prevents unauthorized individuals from participating in collaborative computing sessions without the explicit knowledge of other participants.

SC-3.5 · Layered Structures Control Statement: Implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers. Supplemental Guidance: Implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers. The implementation of layered structures with minimized interactions among security functions and non-looping layers (i.e., lower-layer functions do not depend on higher-layer functions) enables the isolation of security functions and the management of complexity.

SC-42.4 · Notice of Collection Control Statement: Employ the following measures to facilitate an individual-s awareness that personally identifiable information is being collected by [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Employ the following

measures to facilitate an individual's awareness that personally identifiable information is being collected by [organization-defined parameter]: [organization-defined parameter]. Awareness that organizational sensors are collecting data enables individuals to more effectively engage in managing their privacy. Measures can include conventional written notices and sensor configurations that make individuals directly or indirectly aware through other devices that the sensor is collecting information. The usability and efficacy of the notice are important considerations.

NIST SP 800-53 Rev 5 control SC-28 (Protection of Information at Rest) is assessed by examining, interviewing, and testing: SC-28 · Protection of Information at Rest Control Statement: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Supplemental Guidance: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Information at rest refers to the state of information when it is not in process or in transit and is located on system components. Such components include internal or external har

NIST SP 800-53 Rev 5 control SC-37 (Out-of-band Channels) is defined as follows: SC-37 · Out-of-band Channels Control Statement: Employ the following out-of-band channels for the physical delivery or electronic transmission of [organization-defined parameter] to [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Employ the following out-of-band channels for the physical delivery or electronic transmission of [organization-defined parameter] to [organization-defined parameter]: [organization-defined parameter]. Out-of-band channels include local, non-network accesses to systems; network paths physically separate from network paths u

NIST SP 800-53 Rev 5 control SC-39.1 (Hardware Separation) is assessed by examining, interviewing, and testing: SC-39.1 · Hardware Separation Control Statement: Implement hardware separation mechanisms to facilitate process isolation. Supplemental Guidance: Implement hardware separation mechanisms to facilitate process isolation. Hardware-based separation of system processes is generally less susceptible to compromise than software-based separation, thus providing greater assurance that the separation will be enforced. Hardware separation mechanisms include hardware memory management.

NIST SP 800-171 Rev 3 control 03.13.15 (03.13.15 Session Authenticity) falls under the System and Communications Protection family. 03.13.15 · Session Authenticity Supplemental Guidance: Protecting session authenticity addresses communications protection at the session level, not at the packet level. Such protection establishes grounds for confidence at both ends of the communications sessions in the ongoing identities of other parties and the validity of the transmitted information. Authenticity protection includes protecting against adversary-in-the-middle attacks, session hijacking, and the insertion of false information Supplemental Guidance: Protecting session authenticity addresses communications protection at the session level, not at the packet level. Such protection establishes grounds for confidence at both ends of the communications sessions in the ongoing identities of other parties and the validity of the transmitted information. Authenticity protection includes protecting against adversary-in-the-middle attacks, session hijacking, and the insertion of false information into sessions.

NIST SP 800-53 Rev 5 control SC-7.23 (Disable Sender Feedback on Protocol Validation Failure) is assessed by examining, interviewing, and testing: SC-7.23 · Disable Sender Feedback on Protocol Validation Failure Control Statement: Disable feedback to senders on protocol format validation failure. Supplemental Guidance: Disable feedback to senders on protocol format validation failure. Disabling feedback to senders when there is a failure in protocol validation format prevents adversaries from obtaining information that would otherwise be unavailable.

NIST SP 800-53 Rev 5 control SC-16.2 (Anti-spoofing Mechanisms) summarizes the requirements for this control: SC-16.2 · Anti-spoofing Mechanisms Control Statement: Implement anti-spoofing mechanisms to prevent adversaries from falsifying the security attributes indicating the successful application of the security process. Supplemental Guidance: Implement anti-spoofing mechanisms to prevent adversaries from falsifying the security attributes indicating the successful application of the security process. Some attack vectors operate by altering the security attributes of an information system to intenti

NIST SP 800-53 Rev 5 control SC-36 (Distributed Processing and Storage) summarizes the requirements for this control: SC-36 · Distributed Processing and Storage Control Statement: Distribute the following processing and storage components across multiple [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Distribute the following processing and storage components across multiple [organization-defined parameter]: [organization-defined parameter]. Distributing processing and storage across multiple physical locations or logical domains provides a degree of redundancy or ov

NIST SP 800-53 Rev 5 control SC-41 (Port and I/O Device Access) summarizes the requirements for this control: SC-41 · Port and I/O Device Access Control Statement: [organization-defined parameter] disable or remove [organization-defined parameter] on the following systems or system components: [organization-defined parameter]. Supplemental Guidance: [organization-defined parameter] disable or remove [organization-defined parameter] on the following systems or system components: [organization-defined parameter]. Connection ports include Universal Serial Bus (USB), Thunderbolt, and Firewire (IEEE 1394).

NIST SP 800-53 Rev 5 control SC-13 (Cryptographic Protection) summarizes the requirements for this control: SC-13 · Cryptographic Protection Control Statement: a. Determine the [organization-defined parameter] ; and b. Implement the following types of cryptography required for each specified cryptographic use: [organization-defined parameter]. Supplemental Guidance: a. Determine the [organization-defined parameter] ; and b. Implement the following types of cryptography required for each specified cryptographic use: [organization-defined parameter]. Cryptography can be employed to support a variety o

NIST SP 800-53 Rev 5 control SC-5.1 (Restrict Ability to Attack Other Systems) summarizes the requirements for this control: SC-5.1 · Restrict Ability to Attack Other Systems Control Statement: Restrict the ability of individuals to launch the following denial-of-service attacks against other systems: [organization-defined parameter]. Supplemental Guidance: Restrict the ability of individuals to launch the following denial-of-service attacks against other systems: [organization-defined parameter]. Restricting the ability of individuals to launch denial-of-service attacks requires the mechanisms commonly used for suc

NIST SP 800-53 Rev 5 control SC-7.15 (Networked Privileged Accesses) is assessed by examining, interviewing, and testing: SC-7.15 · Networked Privileged Accesses Control Statement: Route networked, privileged accesses through a dedicated, managed interface for purposes of access control and auditing. Supplemental Guidance: Route networked, privileged accesses through a dedicated, managed interface for purposes of access control and auditing. Privileged access provides greater accessibility to system functions, including security functions. Adversaries attempt to gain privileged access to systems through remote ac

NIST SP 800-53 Rev 5 control SC-40.1 (Electromagnetic Interference) is assessed by examining, interviewing, and testing: SC-40.1 · Electromagnetic Interference Control Statement: Implement cryptographic mechanisms that achieve [organization-defined parameter] against the effects of intentional electromagnetic interference. Supplemental Guidance: Implement cryptographic mechanisms that achieve [organization-defined parameter] against the effects of intentional electromagnetic interference. The implementation of cryptographic mechanisms for electromagnetic interference protects systems against intentional jamming

NIST SP 800-171 Rev 3 control 03.13.09 (03.13.09 Network Disconnect) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SC-16.2 (Anti-spoofing Mechanisms) is assessed by examining, interviewing, and testing: SC-16.2 · Anti-spoofing Mechanisms Control Statement: Implement anti-spoofing mechanisms to prevent adversaries from falsifying the security attributes indicating the successful application of the security process. Supplemental Guidance: Implement anti-spoofing mechanisms to prevent adversaries from falsifying the security attributes indicating the successful application of the security process. Some attack vectors operate by altering the security attributes

of an information system to intenti

NIST SP 800-171 Rev 3 control 03.13.15 (03.13.15 Session Authenticity) is assessed by examining the following: Assessment Objectives: - the authenticity of communications sessions is protected.

NIST SP 800-53 Rev 5 control SC-23 (Session Authenticity) summarizes the requirements for this control: SC-23 · Session Authenticity Control Statement: Protect the authenticity of communications sessions. Supplemental Guidance: Protect the authenticity of communications sessions. Protecting session authenticity addresses communications protection at the session level, not at the packet level. Such protection establishes grounds for confidence at both ends of communications sessions in the ongoing identities of other parties and the validity of transmitted information. Authenticity protection inc

NIST SP 800-53 Rev 5 control SC-43 (Usage Restrictions) summarizes the requirements for this control: SC-43 · Usage Restrictions Control Statement: a. Establish usage restrictions and implementation guidelines for the following system components: [organization-defined parameter] ; and b. Authorize, monitor, and control the use of such components within the system. Supplemental Guidance: a. Establish usage restrictions and implementation guidelines for the following system components: [organization-defined parameter] ; and b. Authorize, monitor, and control the use of such components within the

NIST SP 800-53 Rev 5 control SC-8.3 (Cryptographic Protection for Message Externals) is defined as follows: SC-8.3 · Cryptographic Protection for Message Externals Control Statement: Implement cryptographic mechanisms to protect message externals unless otherwise protected by [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to protect message externals unless otherwise protected by [organization-defined parameter]. Cryptographic protection for message externals addresses protection from the unauthorized disclosure of information. Message externals include message headers and routing information. Cryptographic protection prevents the exploitation of messag

NIST SP 800-53 Rev 5 control SC-12.6 (Physical Control of Keys) is assessed by examining, interviewing, and testing: SC-12.6 · Physical Control of Keys Control Statement: Maintain physical control of cryptographic keys when stored information is encrypted by external service providers. Supplemental Guidance: Maintain physical control of cryptographic keys when stored information is encrypted by external service providers. For organizations that use external service providers (e.g., cloud service or data center providers), physical control of cryptographic keys provides additional assurance that information s

NIST SP 800-171 Rev 3 control 03.13.06 (03.13.06 Network Communications · Deny by Default · Allow by Exception) requires organizations to implement the following: 03.13.06 · Network Communications · Deny by Default · Allow by Exception Supplemental Guidance: This requirement applies to inbound and outbound network communications traffic at the system boundary and at identified points within the system. A deny-all, allow-by-exception network communications traffic policy ensures that only essential and approved connections are allowed. Assessment Objectives: - network communications traffic is denied by default. - network communications traffic is allowe For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.06.

NIST SP 800-53 Rev 5 control SC-8.5 (Protected Distribution System) is assessed by examining, interviewing, and testing: SC-8.5 · Protected Distribution System Control Statement: Implement [organization-defined parameter] to [organization-defined parameter] during transmission. Supplemental Guidance: Implement [organization-defined parameter] to [organization-defined parameter] during transmission. The purpose of a protected distribution system is to deter, detect, and/or make difficult physical access to the communication lines that carry national security information.

NIST SP 800-53 Rev 5 control SC-48.1 (Dynamic Relocation of Sensors or Monitoring Capabilities) is defined as follows: SC-48.1 · Dynamic Relocation of Sensors or Monitoring Capabilities Control Statement: Dynamically relocate [organization-defined parameter] to [organization-defined parameter] under the following conditions or circumstances: [organization-defined parameter]. Supplemental

Guidance: Dynamically relocate [organization-defined parameter] to [organization-defined parameter] under the following conditions or circumstances: [organization-defined parameter]. None.

NIST SP 800-53 Rev 5 control SC-6 (Resource Availability) is assessed by examining, interviewing, and testing: SC-6 · Resource Availability Control Statement: Protect the availability of resources by allocating [organization-defined parameter] by [organization-defined parameter]. Supplemental Guidance: Protect the availability of resources by allocating [organization-defined parameter] by [organization-defined parameter]. Priority protection prevents lower-priority processes from delaying or interfering with the system that services higher-priority processes. Quotas prevent users or processes from obtaining

NIST SP 800-171 Rev 3 control 03.13.10 (03.13.10 Cryptographic Key Establishment and Management) requires organizations to implement the following: 03.13.10 · Cryptographic Key Establishment and Management Supplemental Guidance: Cryptographic keys can be established and managed using either manual procedures or automated mechanisms supported by manual procedures. Organizations satisfy key establishment and management requirements in accordance with applicable federal laws, Executive Orders, policies, directives, regulations, and standards that specify appropriate options, levels, and parameters. This requirement is related to [](#/cprt/fra For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.10.

Recommendations to assign a point value of 1 to all CMMC Level 2 security requirements were not accepted. CMMC adopted the scoring as included in the NIST SP 800-171 DoD Assessment Methodology (DoDAM) used by the DCMA DIBCAC and referenced in DFARS clause 252.204-7020. As addressed in § 170.20(a) in this rule, there is qualified standards acceptance between a DCMA DIBCAC High Assessment and CMMC Level 2 certification assessment. Revisions to the CMMC Scoring Methodology will be made concurrently with changes to the DoDAM. The variable point values of 1, 3, and 5 are linked to the NIST determination of Basic Security Requirements and Derived Security Requirements as described in § 170.24. The DoD has updated the rule text at § 170.24 to clarify which requirements may be included on a POA&M. CMMC Level 2 security requirement SC.L2-3.13.11 can be partially effective and may be included on a POA&M if encryption is employed and is not FIPS-validated. The DoD added a definition for enduring exceptions and temporary deficiencies to the rule. § 170.21 addresses POA&Ms for assessments. Security requirement CA.L2-3.12.2 allows for the development and implementation of an operational plan of action designed to correct deficiencies and reduce or eliminate vulnerabilities in organizational systems. These operational plans of action are different from POA&Ms permitted under Conditional assessment. The rule has been updated to make this distinction clear. The CMMC rule does not prohibit the use of an operational plan of action to address necessary information system updates, patches, or reconfiguration as threats evolve. 2. NIST SP 800-171A Jun2018 Assessment Objectives Comment: Multiple comments questioned the role of NIST SP 800-171A Jun2018 Assessment Objectives within the CMMC assessment process. Three comments asked whether all assessment objectives needed to be met to score a security requirement as MET. Two comments questioned the need to report assessment results at the assessment objective level within the CMMC instantiation of eMASS for CMMC Level 2 and CMMC Level 3 certification assessments. Some comments suggested that the DoD allow for contractors to take a more risk-based approach to include compensating controls instead of a strict security requirement-based model. Response:

NIST SP 800-53 Rev 5 control SC-31.3 (Measure Bandwidth in Operational Environments) summarizes the requirements for this control: SC-31.3 · Measure Bandwidth in Operational Environments Control Statement: Measure the bandwidth of [organization-defined parameter] in the operational environment of the system. Supplemental Guidance: Measure the bandwidth of [organization-defined parameter] in the operational environment of the system. Measuring covert channel bandwidth in specified operational environments helps organizations determine how much information can be covertly leaked before such leakage adversely affects mission

NIST SP 800-53 Rev 5 control SC-2 (Separation of System and User Functionality) is defined as follows: SC-2 · Separation of System and User Functionality Control Statement: Separate user functionality, including user interface services, from system management functionality. Supplemental Guidance: Separate user functionality, including user interface services, from system management functionality. System management functionality includes functions that are necessary to administer databases, network components, workstations, or servers. These functions typically

require privileged user access. The separation of user functions from system management functions is physical or logical. Organization

NIST SP 800-171 Rev 3 control 03.13.10 (03.13.10 Cryptographic Key Establishment and Management) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Multiple comments addressed NIST requirements. One comment stated the NIST cybersecurity standards and guidelines are not legal requirements. The commenter recommended edits to the CMMC rule to require contractors implement requirements derived from NIST SP 800-171 R2 with measurable specifications to protect CUI. Two commentors felt the body of the proposed rule should have included a list of the NIST requirements to be assessed at each CMMC level. One comment suggested clarifying when a Systems Security Plan is required for each level. And, one asked if the CMMC Assessment Scope and attestation requirements included Non-Federal Organization (NFO) controls or the flow-down and reporting requirements from DFARS clause 252.204-7012. Some comments were speculative in nature and outside the scope of the rule. One commenter was concerned that a CMMC assessment would not address the risk of insider threats and national security problems driven by political divisions within Congress. Response: DoD is aware of industry concerns regarding FIPS validation required in NIST SP 800-171 R2 requirement 3.13.11. Because this is a NIST requirement, changing it is beyond the scope of the CMMC rule. As stated in § 170.5(3), the CMMC Program does not alter any separately applicable requirements to protect FCI or CUI, including the requirement to use FIPS-validated cryptography which comes from NIST SP 800-171 as required by DFARS clause 252.204-7012. Limitations of the FIPS-validated module process do not impact the implementation status of FIPS cryptography. However, the rule has been updated to allow for Enduring Exceptions and temporary deficiencies, which may apply to the implementation of FIPS. DoD declined to update the rule to include FIPS-compliant encryption as opposed to FIPS-validated encryption. NIST SP 800-171 R2 requires the use of validated modules in specific conditions. Comments on the specific security requirements contained in NIST documentation are beyond the scope of this rule and should be directed to NIST. Collaboration between DoD and NIST about the NIST cryptographic module validation program, or to define cryptography related ODPs in NIST SP 800-171 Revision 3, is also beyond the scope of the rule. Recommendations for desired changes in NIST documentation should be directed to NIST. The NIST Cryptographic Module Validation Program website provides a list of approved solutions and their timelines: <https://csrc.nist.gov/projects/cryptographic-module-validation-program>. NIST SP 800-171 information security requirements were codified in 32 CFR part 2002 in response to guidance (in E.O. 13556) to standardize Federal agency policies for safeguarding CUI. The DoD has elected to use FAR clause 52.204-21, NIST SP 800-171 R2, and a subset of NIST SP 800-172 Feb2021 as the basis for the security requirements in this rule.

NIST SP 800-171 Rev 3 control 03.13.04 (03.13.04 Information in Shared System Resources) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SC-45.1 (Synchronization with Authoritative Time Source) summarizes the requirements for this control: SC-45.1 Synchronization with Authoritative Time Source Control Statement: (a) Compare the internal system clocks [organization-defined parameter] with [organization-defined parameter]; and (b) Synchronize the internal system clocks to the authoritative time source when the time difference is greater than [organization-defined parameter]. Supplemental Guidance: (a) Compare the internal system clocks [organization-defined parameter] with [organization-defined parameter]; and (b) Synchronize

Under the FedRAMP Low baseline, SC-8 (SC-8 Transmission Confidentiality and Integrity): FedRAMP Low Baseline SC-8 Transmission Confidentiality and Integrity Control Statement: Protect the [organization-defined parameter] of transmitted information. Supplemental Guidance: Protect the [organization-defined parameter] of transmitted information. Protecting the confidentiality and integrity of transmitted information applies to internal and external networks as well as any system components that can transmit information, including servers, notebook computers, desktop computers,

SC-51 · Hardware-based Protection Control Statement: a. Employ hardware-based, write-protect for [organization-defined parameter] ; and b. Implement specific procedures for [organization-defined parameter] to manually disable hardware write-protect for firmware modifications and re-enable the write-protect prior to returning to operational mode. Supplemental Guidance: a. Employ hardware-based, write-protect for [organization-defined parameter] ; and b. Implement specific procedures for [organization-defined parameter] to manually disable hardware write-protect for firmware modifications and re-enable the write-protect prior to returning to operational mode. None.

NIST SP 800-171 Rev 3 control 03.13.11 (03.13.11 Cryptographic Protection) requires organizations to implement the following: 03.13.11 · Cryptographic Protection Supplemental Guidance: Cryptography is implemented in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, and guidelines. FIPS-validated cryptography is recommended for the protection of CUI. Assessment Objectives: - the following types of cryptography are implemented to protect the confidentiality of CUI: [organization-defined parameter]. Organization-Defined Parameters: - A.03.13.11.ODP.01: types of cryptograph For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.11.

NIST SP 800-53 Rev 5 control SC-10 (Network Disconnect) summarizes the requirements for this control: SC-10 · Network Disconnect Control Statement: Terminate the network connection associated with a communications session at the end of the session or after [organization-defined parameter] of inactivity. Supplemental Guidance: Terminate the network connection associated with a communications session at the end of the session or after [organization-defined parameter] of inactivity. Network disconnect applies to internal and external networks. Terminating network connections associated with speci

NIST SP 800-53 Rev 5 control SC-8.2 (Pre- and Post-transmission Handling) summarizes the requirements for this control: SC-8.2 · Pre- and Post-transmission Handling Control Statement: Maintain the [organization-defined parameter] of information during preparation for transmission and during reception. Supplemental Guidance: Maintain the [organization-defined parameter] of information during preparation for transmission and during reception. Information can be unintentionally or maliciously disclosed or modified during preparation for transmission or during reception, including during aggregation, at protocol tr

NIST SP 800-53 Rev 5 control SC-17 (Public Key Infrastructure Certificates) summarizes the requirements for this control: SC-17 · Public Key Infrastructure Certificates Control Statement: a. Issue public key certificates under an [organization-defined parameter] or obtain public key certificates from an approved service provider; and b. Include only approved trust anchors in trust stores or certificate stores managed by the organization. Supplemental Guidance: a. Issue public key certificates under an [organization-defined parameter] or obtain public key certificates from an approved service provider; and b. Incl

NIST SP 800-53 Rev 5 control SC-3.5 (Layered Structures) is assessed by examining, interviewing, and testing: SC-3.5 · Layered Structures Control Statement: Implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers. Supplemental Guidance: Implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers. The implementation of

NIST SP 800-171 Rev 3 control 03.13.01 (03.13.01 Boundary Protection) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SC-1 (Policy and Procedures) is defined as follows: SC-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined

parameter]: 1. [organization-defined parameter] system and communications protection policy that:
2. Procedures to facilitate the implementation of the system and communications protection policy and the associated system and communications protection controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the system and communications protection policy and procedures; and c. Review and update the current system an

NIST SP 800-171 Rev 3 control 03.13.04 (03.13.04 Information in Shared System Resources) is assessed by examining the following: Assessment Objectives: - unauthorized information transfer via shared system resources is prevented. - unintended information transfer via shared system resources is prevented.

NIST SP 800-171 Rev 3 control 03.13.15 (03.13.15 Session Authenticity) is assessed by examining the following: Assessment Objectives: - the authenticity of communications sessions is protected.

NIST SP 800-171 Rev 3 control 03.13.13 (03.13.13 Mobile Code) is assessed by examining the following: Assessment Objectives: - the use of mobile code is authorized. - the use of mobile code is monitored. - the use of mobile code is controlled. - acceptable mobile code is defined. - acceptable mobile code technologies are defined.

From the NIST SP 800-172 Rev 3 Final Public Draft: A DVERSARY EFFECTS Preclude (Preempt), Impede (Contain) REFERENCES Source Control: SC-25 03.1 3.12E Denial-of-Service Protection a. [Selection (one): Protect against; Limit] the effects of the following types of denial-of-service events: [Assignment: organization-defined types of denial-of-service events]. b. Employ the following safeguards to prevent the denial-of-service events[Assignment: organization-defined safeguards by type of denial-of-service event]. DISCUSSION Denial-of-service events may occur due to a variety of internal and external causes, such as an attack by an adversary or a lack of planning to support organizational needs with respect to capacity and bandwidth. Such attacks can occur across a wide range of network protocols (e.g., IPv4, IPv6). A variety of

Control SC-42: R THREE PAGE 326 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5.1>

NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Verify that the system is configured so that data or information collected by the [Assignment: organization-defined sensors] is only reported to authorized individuals or roles. Discussion: In situations where sensors are activated by authorized individuals, it is still possible that the data or information collected by the sensors will be sent to unauthorized entities. Related Controls: None. (2) SENSOR CAPABILITY AND DATA | AUTHORIZED USE Employ the following measures so that data or information collected by [Assignment: organization-defined sensors] is only used for authorized purposes: [Assignment: organization-defined measures]. Discussion: Information collected by sensors for a specific authorized purpose could be misused for some unauthorized purpose. For example, GPS sensors that are used to support traffic navigation could be misused to track the movements of individuals. Measures to mitigate such activities include additional training to help ensure that authorized individuals do not abuse their authority and, in the case where sensor data is maintained by external parties, contractual restrictions on the use of such data. Related Controls: PT-2.

SC-8.5 · Protected Distribution System Control Statement: Implement [organization-defined parameter] to [organization-defined parameter] during transmission. Supplemental Guidance: Implement [organization-defined parameter] to [organization-defined parameter] during transmission. The purpose of a protected distribution system is to deter, detect, and/or make difficult physical access to the communication lines that carry national security information.

NIST SP 800-53 Rev 5 control SC-17 (Public Key Infrastructure Certificates) is assessed by examining, interviewing, and testing: SC-17 · Public Key Infrastructure Certificates Control Statement: a. Issue public key certificates under an [organization-defined parameter] or obtain public key certificates from an approved service provider; and b. Include only approved trust anchors in trust stores or certificate stores managed by the organization. Supplemental Guidance: a. Issue public key certificates under an [organization-defined parameter] or obtain public key certificates from an approved service provider; and b. Incl

03.13.09 · Network Disconnect Supplemental Guidance: This requirement applies to internal and external networks. Terminating network connections associated with communications sessions includes deallocating TCP/IP addresses or port pairs at the operating system level or deallocating networking assignments at the application level if multiple application sessions are using a single network connection. Time periods of inactivity may be established by organizations and include time periods by type of network access or for specific network accesses. Assessment Objectives: - the network connection associated with a communications session is terminated at the end of the session or after [organization-defined parameter] of inactivity. Organization-Defined Parameters: - A.03.13.09.ODP.01: time period

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA, CRS ADVERSARY EFFECTS Preclude (Preempt, Negate), Impede (Exert), Limit (Reduce) REFERENCES Source Control: SC-05 NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.13.13E Port and Input/Output Device Access 1997

SC-34 · Non-modifiable Executable Programs Control Statement: For [organization-defined parameter] , load and execute: a. The operating environment from hardware-enforced, read-only media; and b. The following applications from hardware-enforced, read-only media: [organization-defined parameter]. Supplemental Guidance: For [organization-defined parameter] , load and execute: a. The operating environment from hardware-enforced, read-only media; and b. The following applications from hardware-enforced, read-only media: [organization-defined parameter]. The operating environment for a system contains the code that hosts applications, including operating systems, executives, or virtual machine monitors (i.e., hypervisors). It can also include certain applications that run directly on hardware platforms. Hardware-enforced, read-only media include Compact Disc-Recordable (CD-R) and Digital Versatile Disc-Recordable (DVD-R) disk drives as well as one-time, programmable, read-only memory. The use of non-modifiable storage ensures the integrity of software from the point of creation of the read-only image. The use of reprogrammable, read-only memory can be accepted as read-only media provided that integrity can be adequately protected from the point of initial writing to the insertion of the memory into the system, and there are reliable hardware protections against reprogramming the memory while installed in organizational systems.

NIST SP 800-53 Rev 5 control SC-2.2 (Disassociability) is assessed by examining, interviewing, and testing: SC-2.2 · Disassociability Control Statement: Store state information from applications and software separately. Supplemental Guidance: Store state information from applications and software separately. If a system is compromised, storing applications and software separately from state information about users' interactions with an application may better protect individuals' privacy.

NIST SP 800-53 Rev 5 control SC-32 (System Partitioning) is defined as follows: SC-32 · System Partitioning Control Statement: Partition the system into [organization-defined parameter] residing in separate [organization-defined parameter] domains or environments based on [organization-defined parameter]. Supplemental Guidance: Partition the system into [organization-defined parameter] residing in separate [organization-defined parameter] domains or environments based on [organization-defined parameter]. System partitioning is part of a defense-in-depth protection strategy. Organizations determine the degree of physical separation of system components. Physical separati

Implementing 03.13.15 (03.13.15 Session Authenticity) differs between cloud and on-premises environments in several ways: **On-premises**: The organization has direct control over all infrastructure components. Implementation of 03.13.15 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. **Cloud (IaaS/PaaS/SaaS)**: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.13.15 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control SC-49 (Hardware-enforced Separation and Policy Enforcement) is assessed by examining, interviewing, and testing: SC-49 · Hardware-enforced Separation and Policy Enforcement Control Statement: Implement hardware-enforced separation and policy enforcement mechanisms between [organization-defined parameter]. Supplemental Guidance: Implement hardware-enforced separation and policy enforcement mechanisms between [organization-defined parameter]. System owners may require additional strength of mechanism and robustness to ensure domain separation and policy enforcement for specific types of threats and environ

NIST SP 800-53 Rev 5 control SC-3.5 (Layered Structures) summarizes the requirements for this control: SC-3.5 · Layered Structures Control Statement: Implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers. Supplemental Guidance: Implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers. The implementation of

NIST SP 800-53 Rev 5 control SC-8.5 (Protected Distribution System) summarizes the requirements for this control: SC-8.5 · Protected Distribution System Control Statement: Implement [organization-defined parameter] to [organization-defined parameter] during transmission. Supplemental Guidance: Implement [organization-defined parameter] to [organization-defined parameter] during transmission. The purpose of a protected distribution system is to deter, detect, and/or make difficult physical access to the communication lines that carry national security information.

Control SC-12: idance on cryptographic key establishment schemes and key derivation methods. [SP 800-57-1], [SP 800-57-2], and [SP 800-57-3] provide guidance on cryptographic key management. Related Controls: None. (4) CRYPTOGRAPHIC KEY ESTABLISHMENT AND MANAGEMENT | PKI CERTIFICATES [Withdrawn: Incorporated into SC-12(3).] (5) CRYPTOGRAPHIC KEY ESTABLISHMENT AND MANAGEMENT | PKI CERTIFICATES / HARDWARE TOKENS [Withdrawn: Incorporated into SC-12(3).] (6) CRYPTOGRAPHIC KEY ESTABLISHMENT AND MANAGEMENT | PHYSICAL CONTROL OF KEYS Maintain physical control of cryptographic keys when stored information is encrypted by external service providers. Discussion: For organizations that use external service providers (e.g., cloud service or data center providers), physical control of cryptographic keys provides additional assurance that information stored by such external providers is not subject to unauthorized disclosure or modification. Related Controls: None. References: [FIPS 140-3], [SP 800-56A], [SP 800-56B], [SP 800-56C], [SP 800-57-1], [SP 800-57-2], [SP 800-57-3], [SP 800-63-3], [IR 7956], [IR 7966].

Under the FedRAMP Moderate baseline, SC-39 (SC-39 Process Isolation): FedRAMP Moderate Baseline · SC-39 · Process Isolation Control Statement: Maintain a separate execution domain for each executing system process. Supplemental Guidance: Maintain a separate execution domain for each executing system process. Systems can maintain separate execution domains for each executing process by assigning each process a separate address space. Each system process has a distinct address space so that communication between processes is performed in a manner controlled throug

Under the FedRAMP Moderate baseline, SC-7 (SC-7 Boundary Protection): FedRAMP Moderate Baseline · SC-7 · Boundary Protection Control Statement: a. Monitor and control communications at the external managed interfaces to the system and at key internal managed interfaces within the system; b. Implement subnetworks for publicly accessible system components that are [organization-defined parameter] separated from internal organizational networks; and c. Connect to external networks or systems only through managed interfaces consisting of boundary protection devices a

NIST SP 800-53 Rev 5 control SC-28 (Protection of Information at Rest) is defined as follows: SC-28 · Protection of Information at Rest Control Statement: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Supplemental Guidance: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Information at rest refers to the state of information when it is not in process or in transit and is located on system components. Such components include internal or external hard disk drives, storage area network devices, or databases. However, the focus of protecting informat

Under the FedRAMP High baseline, SC-24 (SC-24 Fail in Known State): FedRAMP High Baseline · SC-24 · Fail in Known State Control Statement: Fail to a [organization-defined parameter] for the following

failures on the indicated components while preserving [organization-defined parameter] in failure: [organization-defined parameter]. Supplemental Guidance: Fail to a [organization-defined parameter] for the following failures on the indicated components while preserving [organization-defined parameter] in failure: [organization-defined parameter]. Failure in a kno

NIST SP 800-171 Rev 3 control 03.13.11 (03.13.11 Cryptographic Protection) falls under the System and Communications Protection family. 03.13.11 · Cryptographic Protection Supplemental Guidance: Cryptography is implemented in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, and guidelines. FIPS-validated cryptography is recommended for the protection of CUI. Assessment Objectives: - the following types of cryptography are implemented to protect the confidentiality of CUI: [organization-defined parameter]. Organization-Defined Parameters: - A.03.13.11.ODP.01: types of cryptograph Supplemental Guidance: Cryptography is implemented in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, and guidelines. FIPS-validated cryptography is recommended for the protection of CUI.

NIST SP 800-53 Rev 5 control SC-3.1 (Hardware Separation) is assessed by examining, interviewing, and testing: SC-3.1 · Hardware Separation Control Statement: Employ hardware separation mechanisms to implement security function isolation. Supplemental Guidance: Employ hardware separation mechanisms to implement security function isolation. Hardware separation mechanisms include hardware ring architectures that are implemented within microprocessors and hardware-enforced address segmentation used to support logically distinct storage objects with separate attributes (i.e., readable, writeable).

NIST SP 800-53 Rev 5 control SC-5 (Denial-of-service Protection) summarizes the requirements for this control: SC-5 · Denial-of-service Protection Control Statement: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b. Employ the following controls to achieve the denial-of-service objective: [organization-defined parameter]. Supplemental Guidance: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b. Employ the following control

Control SC-50: SOFTWARE-ENFORCED SEPARATION AND POLICY ENFORCEMENT Control: Implement software-enforced separation and policy enforcement mechanisms between [Assignment: organization-defined security domains]. Discussion: System owners may require additional strength of mechanism to ensure domain separation and policy enforcement for specific types of threats and environments of operation. Related Controls: AC-3, AC-4, SA-8, SC-2, SC-3, SC-49. Control Enhancements: None. References: [SP 800-160-1]. CHAPTER THREE PAGE 330 NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

SC-7.8 · Route Traffic to Authenticated Proxy Servers Control Statement: Route [organization-defined parameter] to [organization-defined parameter] through authenticated proxy servers at managed interfaces. Supplemental Guidance: Route [organization-defined parameter] to [organization-defined parameter] through authenticated proxy servers at managed interfaces. External networks are networks outside of organizational control. A proxy server is a server (i.e., system or application) that acts as an intermediary for clients requesting system resources from non-organizational or other organizational servers. System resources that may be requested include files, connections, web pages, or services. Client requests established through a connection to a proxy server are assessed to manage complexity and provide additional protection by limiting direct connectivity. Web content filtering devices are one of the most common proxy servers that provide access to the Internet. Proxy servers can support the logging of Transmission Control Protocol sessions and the blocking of specific Uniform Resource Locators, Internet Protocol addresses, and domain names. Web proxies can be configured with organization-defined lists of authorized and unauthorized websites. Note that proxy servers may inhibit the use of virtual private networks (VPNs) and create the potential for "man-in-the-middle" attacks (depending on the implementation).

NIST SP 800-53 Rev 5 control SC-7.4 (External Telecommunications Services) summarizes the requirements for this control: SC-7.4 · External Telecommunications Services Control Statement: (a) Implement a managed interface for each external telecommunication service; (b) Establish a traffic flow policy for each managed interface; (c) Protect the confidentiality and integrity of the

information being transmitted across each interface; (d) Document each exception to the traffic flow policy with a supporting mission or business need and duration of that need; (e) Review exceptions to the traffic flow policy [organization]

NIST SP 800-53 Rev 5 control SC-8.4 (Conceal or Randomize Communications) summarizes the requirements for this control: SC-8.4 · Conceal or Randomize Communications Control Statement: Implement cryptographic mechanisms to conceal or randomize communication patterns unless otherwise protected by [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to conceal or randomize communication patterns unless otherwise protected by [organization-defined parameter]. Concealing or randomizing communication patterns addresses protection from unauthorized disclosure of information. Comm

NIST SP 800-53 Rev 5 control SC-7.17 (Automated Enforcement of Protocol Formats) is assessed by examining, interviewing, and testing: SC-7.17 · Automated Enforcement of Protocol Formats Control Statement: Enforce adherence to protocol formats. Supplemental Guidance: Enforce adherence to protocol formats. System components that enforce protocol formats include deep packet inspection firewalls and XML gateways. The components verify adherence to protocol formats and specifications at the application layer and identify vulnerabilities that cannot be detected by devices operating at the network or transport layers.

Under the FedRAMP Low baseline, SC-22 (SC-22 Architecture and Provisioning for Name/Address Resolution Service): FedRAMP Low Baseline · SC-22 · Architecture and Provisioning for Name/Address Resolution Service Control Statement: Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external role separation. Supplemental Guidance: Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external role separation. Systems that provide

NIST SP 800-53 Rev 5 control SC-34.2 (Integrity Protection on Read-only Media) summarizes the requirements for this control: SC-34.2 · Integrity Protection on Read-only Media Control Statement: Protect the integrity of information prior to storage on read-only media and control the media after such information has been recorded onto the media. Supplemental Guidance: Protect the integrity of information prior to storage on read-only media and control the media after such information has been recorded onto the media. Controls prevent the substitution of media into systems or the reprogramming of programmable read-only

NIST SP 800-53 Rev 5 control SC-30.4 (Misleading Information): SC-30.4 · Misleading Information Control Statement: Employ realistic, but misleading information in [organization-defined parameter] about its security state or posture. Supplemental Guidance: Employ realistic, but misleading information in [organization-defined parameter] about its security state or posture. Employing misleading information is intended to confuse potential adversaries regarding

From the NIST SP 800-172 Rev 3 Final Public Draft: Source Control: SC-29(01) 03.1 3.08E Decoys Include components within organizational systems specifically designed to be the target of malicious attacks for detecting, deflecting, and analyzing such attacks. DISCUSSION Decoys (i.e., honeypots, honeynets, or deception nets) are established to attract adversaries and deflect attacks away from the operational systems that support organizational missions and business functions. The use of decoys requires some supporting isolation measures to ensure that any deflected malicious code does not infect organizational systems. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY DLO, CRS AD

Under the FedRAMP High baseline, SC-28 (SC-28 Protection of Information at Rest): FedRAMP High Baseline · SC-28 · Protection of Information at Rest Control Statement: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Supplemental Guidance: Protect the [organization-defined parameter] of the following information at rest: [organization-defined parameter]. Information at rest refers to the state of information when it is not in process or in transit and is located on system components. Such components include

NIST SP 800-53 Rev 5 control SC-41 (Port and I/O Device Access) is assessed by examining,

interviewing, and testing: SC-41 · Port and I/O Device Access Control Statement: [organization-defined parameter] disable or remove [organization-defined parameter] on the following systems or system components: [organization-defined parameter]. Supplemental Guidance: [organization-defined parameter] disable or remove [organization-defined parameter] on the following systems or system components: [organization-defined parameter]. Connection ports include Universal Serial Bus (USB), Thunderbolt, and Firewire (IEEE 1394).

NIST SP 800-53 Rev 5 control SC-38 (Operations Security): SC-38 · Operations Security Control Statement: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defined parameter]. Supplemental Guidance: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defi

NIST SP 800-53 Rev 5 control SC-32 (System Partitioning) summarizes the requirements for this control: SC-32 · System Partitioning Control Statement: Partition the system into [organization-defined parameter] residing in separate [organization-defined parameter] domains or environments based on [organization-defined parameter]. Supplemental Guidance: Partition the system into [organization-defined parameter] residing in separate [organization-defined parameter] domains or environments based on [organization-defined parameter]. System partitioning is part of a defense-in-depth protection strateg

NIST SP 800-53 Rev 5 control SC-45 (System Time Synchronization) is assessed by examining, interviewing, and testing: SC-45 · System Time Synchronization Control Statement: Synchronize system clocks within and between systems and system components. Supplemental Guidance: Synchronize system clocks within and between systems and system components. Time synchronization of system clocks is essential for the correct execution of many system services, including identification and authentication processes that involve certificates and time-of-day restrictions as part of access control. Denial of service or failure t

NIST SP 800-53 Rev 5 control SC-34 (Non-modifiable Executable Programs) summarizes the requirements for this control: SC-34 · Non-modifiable Executable Programs Control Statement: For [organization-defined parameter] , load and execute: a. The operating environment from hardware-enforced, read-only media; and b. The following applications from hardware-enforced, read-only media: [organization-defined parameter]. Supplemental Guidance: For [organization-defined parameter] , load and execute: a. The operating environment from hardware-enforced, read-only media; and b. The following applications from hardware-en

From the NIST SP 800-172 Rev 3 Final Public Draft: Platform-independent applications are 1874 applications with the capability to execute on multiple platforms. Such applications promote portability and reconstitution on different platforms. The portability of applications and the ability to reconstitute applications on different platforms increase the availability of mission-essential functions within organizations when systems with specific operating systems are under attack. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. P
ROTECTION STRATEGY CRS ADVERSARY EFFECTS Limit (Shorten, Reduce) REFERENCES Source Control: SC-27 03.1 3.07E Virtualization Techniques Employ virtualization techniques to

NIST SP 800-171 Rev 3 control 03.13.04 (03.13.04 Information in Shared System Resources) is assessed by examining the following: Assessment Objectives: - unauthorized information transfer via shared system resources is prevented. - unintended information transfer via shared system resources is prevented.

Under the FedRAMP High baseline, SC-8 (SC-8 Transmission Confidentiality and Integrity): FedRAMP High Baseline · SC-8 · Transmission Confidentiality and Integrity Control Statement: Protect the [organization-defined parameter] of transmitted information. Supplemental Guidance: Protect the [organization-defined parameter] of transmitted information. Protecting the confidentiality and integrity of transmitted information applies to internal and external networks as well as any system components that can transmit information, including servers, notebook computers, desktop computers,

NIST SP 800-171 Rev 3 control 03.13.11 (03.13.11 Cryptographic Protection) is assessed by examining

the following: Assessment Objectives: - the following types of cryptography are implemented to protect the confidentiality of CUI: [organization-defined parameter].

SC-2.1 · Interfaces for Non-privileged Users Control Statement: Prevent the presentation of system management functionality at interfaces to non-privileged users. Supplemental Guidance: Prevent the presentation of system management functionality at interfaces to non-privileged users. Preventing the presentation of system management functionality at interfaces to non-privileged users ensures that system administration options, including administrator privileges, are not available to the general user population. Restricting user access also prohibits the use of the grey-out option commonly used to eliminate accessibility to such information. One potential solution is to withhold system administration options until users establish sessions with administrator privileges.

NIST SP 800-53 Rev 5 control SC-47 (Alternate Communications Paths) summarizes the requirements for this control: SC-47 · Alternate Communications Paths Control Statement: Establish [organization-defined parameter] for system operations organizational command and control. Supplemental Guidance: Establish [organization-defined parameter] for system operations organizational command and control. An incident, whether adversarial- or nonadversarial-based, can disrupt established communications paths used for system operations and organizational command and control. Alternate communications paths reduce the ri

NIST SP 800-53 Rev 5 control SC-4 (Information in Shared System Resources) is defined as follows: SC-4 · Information in Shared System Resources Control Statement: Prevent unauthorized and unintended information transfer via shared system resources. Supplemental Guidance: Prevent unauthorized and unintended information transfer via shared system resources. Preventing unauthorized and unintended information transfer via shared system resources stops information produced by the actions of prior users or roles (or the actions of processes acting on behalf of prior users or roles) from being available to current users or roles (or current processes acting on behalf of current users or roles)

Under the FedRAMP High baseline, SC-7 (SC-7 Boundary Protection): FedRAMP High Baseline · SC-7 · Boundary Protection Control Statement: a. Monitor and control communications at the external managed interfaces to the system and at key internal managed interfaces within the system; b. Implement subnetworks for publicly accessible system components that are [organization-defined parameter] separated from internal organizational networks; and c. Connect to external networks or systems only through managed interfaces consisting of boundary protection devices arran

NIST SP 800-171 Rev 3 control 03.13.04 (03.13.04 Information in Shared System Resources) falls under the System and Communications Protection family. 03.13.04 · Information in Shared System Resources Supplemental Guidance: Preventing unauthorized and unintended information transfer via shared system resources stops information produced by the actions of prior users or roles (or actions of processes acting on behalf of prior users or roles) from being available to current users or roles (or current processes acting on behalf of current users or roles) that obtain access to shared system resources after those resources have been released back Supplemental Guidance: Preventing unauthorized and unintended information transfer via shared system resources stops information produced by the actions of prior users or roles (or actions of processes acting on behalf of prior users or roles) from being available to current users or roles (or current processes acting on behalf of current users or roles) that obtain access to shared system resources after those resources have been released back to the system. Information in shared system resourc

NIST SP 800-53 Rev 5 control SC-7.20 (Dynamic Isolation and Segregation) is assessed by examining, interviewing, and testing: SC-7.20 · Dynamic Isolation and Segregation Control Statement: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. Supplemental Guidance: Provide the capability to dynamically isolate [organization-defined parameter] from other system components. The capability to dynamically isolate certain internal system components is useful when it is necessary to partition or separate system components of questionable origin from components that pos

NIST SP 800-53 Rev 5 control SC-7.7 (Split Tunneling for Remote Devices) summarizes the requirements for this control: SC-7.7 · Split Tunneling for Remote Devices Control Statement: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is

securely provisioned using [organization-defined parameter]. Supplemental Guidance: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [organization-defined parameter]. Split tunneling is the process of allowing a remote user or device to establish

SC-7.11 · Restrict Incoming Communications Traffic Control Statement: Only allow incoming communications from [organization-defined parameter] to be routed to [organization-defined parameter]. Supplemental Guidance: Only allow incoming communications from [organization-defined parameter] to be routed to [organization-defined parameter]. General source address validation techniques are applied to restrict the use of illegal and unallocated source addresses as well as source addresses that should only be used within the system. The restriction of incoming communications traffic provides determinations that source and destination address pairs represent authorized or allowed communications. Determinations can be based on several factors, including the presence of such address pairs in the lists of authorized or allowed communications, the absence of such address pairs in lists of unauthorized or disallowed pairs, or meeting more general rules for authorized or allowed source and destination pairs. Strong authentication of network addresses is not possible without the use of explicit security protocols, and thus, addresses can often be spoofed. Further, identity-based incoming traffic restriction methods can be employed, including router access control lists and firewall rules.

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement does not enhance a specific 2032 requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY PRA, DLO ADVERSARY EFFECTS Preclude (Preempt, Negate), Impede (Contain, Exert), Expose (Detect, Reveal) REFERENCES Source Control: SC-44 03.1 3.15E Separate Subnets to Isolate System Components and Functions Implement [Selection (one): physically; logically] separate subnetworks to isolate the following critical system components and functions: [Assignment: organization-defined critical system components and functions]. DISCUSSION Separating critical system components and functions from other noncritical system components and functions through separate subnetworks may be n

NIST SP 800-53 Rev 5 control SC-51 (Hardware-based Protection) is assessed by examining, interviewing, and testing: SC-51 · Hardware-based Protection Control Statement: a. Employ hardware-based, write-protect for [organization-defined parameter] ; and b. Implement specific procedures for [organization-defined parameter] to manually disable hardware write-protect for firmware modifications and re-enable the write-protect prior to returning to operational mode. Supplemental Guidance: a. Employ hardware-based, write-protect for [organization-defined parameter] ; and b. Implement specific procedures for [organi

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA, CRS ADVERSARY EFFECTS Preclude (Preempt), Impede (Contain, Exert), Limit (Reduce) REFERENCES Source Control: SC-29 NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.13.02E Randomness 1773

NIST SP 800-53 Rev 5 control SC-32.1 (Separate Physical Domains for Privileged Functions) summarizes the requirements for this control: SC-32.1 · Separate Physical Domains for Privileged Functions Control Statement: Partition privileged functions into separate physical domains. Supplemental Guidance: Partition privileged functions into separate physical domains. Privileged functions that operate in a single physical domain may represent a single point of failure if that domain becomes compromised or experiences a denial of service.

NIST SP 800-53 Rev 5 control SC-28.1 (Cryptographic Protection) summarizes the requirements for this control: SC-28.1 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. The selection of cryptographic

NIST SP 800-53 Rev 5 control SC-7.16 (Prevent Discovery of System Components) summarizes the requirements for this control: SC-7.16 · Prevent Discovery of System Components Control Statement:

Prevent the discovery of specific system components that represent a managed interface.
Supplemental Guidance: Prevent the discovery of specific system components that represent a managed interface. Preventing the discovery of system components representing a managed interface helps protect network addresses of those components from discovery through common tools and techniques used to identify devices on networks. Network add

NIST SP 800-53 Rev 5 control SC-5.1 (Restrict Ability to Attack Other Systems) is assessed by examining, interviewing, and testing: SC-5.1 · Restrict Ability to Attack Other Systems Control Statement: Restrict the ability of individuals to launch the following denial-of-service attacks against other systems: [organization-defined parameter]. Supplemental Guidance: Restrict the ability of individuals to launch the following denial-of-service attacks against other systems: [organization-defined parameter]. Restricting the ability of individuals to launch denial-of-service attacks requires the mechanisms commonly used for suc

Under the FedRAMP Moderate baseline, SC-7.12 (SC-7.12 Host-based Protection): FedRAMP Moderate Baseline · SC-7.12 · Host-based Protection Control Statement: Implement [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Implement [organization-defined parameter] at [organization-defined parameter]. Host-based boundary protection mechanisms include host-based firewalls. System components that employ host-based boundary protection mechanisms include servers, workstations, notebook computers, and mobile devices. Assessment Objective

NIST SP 800-53 Rev 5 control SC-21 (Secure Name/Address Resolution Service (Recursive or Caching Resolver)) summarizes the requirements for this control: SC-21 · Secure Name/Address Resolution Service (Recursive or Caching Resolver) Control Statement: Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources. Supplemental Guidance: Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources. Each client of name resolution services e

and CHAPTER THREE PAGE 327 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

b.

Authorize, monitor, and control the use of such components within the system. Discussion: Usage restrictions apply to all system components including but not limited to mobile code, mobile devices, wireless access, and wired and wireless peripheral components (e.g., copiers, printers, scanners, optical devices, and other similar technologies). The usage restrictions and implementation guidelines are based on the potential for system components to cause damage to the system and help to ensure that only authorized system use occurs. Related Controls: AC-18, AC-19, CM-6, SC-7, SC-18. Control Enhancements: None. References: [OMB A-130], [SP 800-124].

NIST SP 800-171 Rev 3 control 03.13.11 (03.13.11 Cryptographic Protection) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP High baseline, SC-20 (SC-20 Secure Name/Address Resolution Service (Authoritative Source)): FedRAMP High Baseline · SC-20 · Secure Name/Address Resolution Service (Authoritative Source) Control Statement: a. Provide additional data origin authentication and integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name/address resolution queries; and b. Provide the means to indicate the security status of child zones and (if the child supports secure resolution services) to enable verification of a chain of trust amon

03.13.06 · Network Communications · Deny by Default · Allow by Exception Supplemental Guidance: This requirement applies to inbound and outbound network communications traffic at the system boundary and at identified points within the system. A deny-all, allow-by-exception network communications traffic policy ensures that only essential and approved connections are allowed.

Assessment Objectives: - network communications traffic is denied by default. - network communications traffic is allowed by exception.

SC.L2-3.13.14 · Voice over Internet Protocol CMMC Assessment Guide · Level 2 | Version 2.13 241

FURTHER DISCUSSION Controlling VoIP technologies starts with establishing guidelines and enforcing the appropriate usage that is described in organizational policies. Monitoring should include the users' activity for anything other than what is permitted and authorized and detection of insecure or unauthorized use of the VoIP technology. Security concerns for VoIP include eavesdropping on calls and using ID spoofing to impersonate trusted individuals. Selecting a solution that can encrypt VoIP traffic is helpful in maintaining the confidentiality and integrity of the voice data.

Example You are a system administrator responsible for the VoIP system. You configure VoIP for new users after being notified that they have signed the Acceptable Use Policy for VoIP technology [a].

You verify that the VoIP solution is configured to use encryption and have enabled requirements for passwords on voice mailboxes and on phone extension management. You require phone system administrators to log in using multifactor authentication when managing the system [a]. You add the VoIP software to the list of applications that are patched monthly as needed [a,b]. Finally, you configure the VoIP system to send logs to your log aggregator so that they can be correlated with those from other systems and examined for signs of suspicious activity [b].

Potential Assessment Considerations · Are VoIP technologies (e.g., approved and managed products or solutions) that may or may not be used in the system defined [a]? · Is monitoring for unapproved VoIP technologies or unapproved use of the allowed VoIP solutions employed [b]? KEY REFERENCES · NIST SP 800-171 Rev.

2 3.13.14

NIST SP 800-53 Rev 5 control SC-15.1 (Physical or Logical Disconnect) is assessed by examining, interviewing, and testing: SC-15.1 · Physical or Logical Disconnect Control Statement: Provide [organization-defined parameter] disconnect of collaborative computing devices in a manner that supports ease of use. Supplemental Guidance: Provide [organization-defined parameter] disconnect of collaborative computing devices in a manner that supports ease of use. Failing to disconnect from collaborative computing devices can result in subsequent compromises of organizational information. Providing easy methods to disconnect

NIST SP 800-53 Rev 5 control SC-7.14 (Protect Against Unauthorized Physical Connections) is defined as follows: SC-7.14 · Protect Against Unauthorized Physical Connections Control Statement: Protect against unauthorized physical connections at [organization-defined parameter]. Supplemental Guidance: Protect against unauthorized physical connections at [organization-defined parameter]. Systems that operate at different security categories or classification levels may share common physical and environmental controls, since the systems may share space within the same facilities. In practice, it is possible that these separate systems may share common equipment rooms, wiring closets, and cable distributio

NIST SP 800-53 Rev 5 control SC-47 (Alternate Communications Paths) is assessed by examining, interviewing, and testing: SC-47 · Alternate Communications Paths Control Statement: Establish [organization-defined parameter] for system operations organizational command and control. Supplemental Guidance: Establish [organization-defined parameter] for system operations organizational command and control. An incident, whether adversarial- or nonadversarial-based, can disrupt established communications paths used for system operations and organizational command and control. Alternate communications paths reduce the ri

NIST SP 800-53 Rev 5 control SC-36.2 (Synchronization) is assessed by examining, interviewing, and testing: SC-36.2 · Synchronization Control Statement: Synchronize the following duplicate systems or system components: [organization-defined parameter]. Supplemental Guidance: Synchronize the following duplicate systems or system components: [organization-defined parameter]. [SC-36](#sc-36) and [CP-9(6)](#cp-9.6) require the duplication of systems or system components in distributed locations. The synchronization of duplicated and redundant services and data helps to ensure that information contained

NIST SP 800-53 Rev 5 control SC-40.3 (Imitative or Manipulative Communications Deception) is assessed by examining, interviewing, and testing: SC-40.3 · Imitative or Manipulative Communications Deception Control Statement: Implement cryptographic mechanisms to identify and reject wireless transmissions that are deliberate attempts to achieve imitative or manipulative

communications deception based on signal parameters. Supplemental Guidance: Implement cryptographic mechanisms to identify and reject wireless transmissions that are deliberate attempts to achieve imitative or manipulative communications deception based on signal parameters.

Under the FedRAMP Moderate baseline, SC-7.5 (SC-7.5 Deny by Default · Allow by Exception): FedRAMP Moderate Baseline · SC-7.5 · Deny by Default · Allow by Exception Control Statement: Deny network communications traffic by default and allow network communications traffic by exception [organization-defined parameter]. Supplemental Guidance: Deny network communications traffic by default and allow network communications traffic by exception [organization-defined parameter]. Denying by default and allowing by exception applies to inbound and outbound network communications traffic. A d

Under the FedRAMP Low baseline, SC-28.1 (SC-28.1 Cryptographic Protection): FedRAMP Low Baseline · SC-28.1 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. The sele

NIST SP 800-53 Rev 5 control SC-31.3 (Measure Bandwidth in Operational Environments) is assessed by examining, interviewing, and testing: SC-31.3 · Measure Bandwidth in Operational Environments Control Statement: Measure the bandwidth of [organization-defined parameter] in the operational environment of the system. Supplemental Guidance: Measure the bandwidth of [organization-defined parameter] in the operational environment of the system. Measuring covert channel bandwidth in specified operational environments helps organizations determine how much information can be covertly leaked before such leakage adversely affects mission

NIST SP 800-53 Rev 5 control SC-1 (Policy and Procedures): SC-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] system and communications protection policy that: 2. Procedures to facilitate the implementation of the system and communications protection policy and the associated system and communications protection controls; b. Designate an [organ

NIST SP 800-53 Rev 5 control SC-38 (Operations Security) summarizes the requirements for this control: SC-38 · Operations Security Control Statement: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defined parameter]. Supplemental Guidance: Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [organization-defined parameter]. Operations security (OPSEC) is a systematic process by which potential adversaries c

Under the FedRAMP Moderate baseline, SC-45 (SC-45 System Time Synchronization): FedRAMP Moderate Baseline · SC-45 · System Time Synchronization Control Statement: Synchronize system clocks within and between systems and system components. Supplemental Guidance: Synchronize system clocks within and between systems and system components. Time synchronization of system clocks is essential for the correct execution of many system services, including identification and authentication processes that involve certificates and time-of-day restrictions as part of access control. De

NIST SP 800-171 Rev 3 control 03.13.09 (03.13.09 Network Disconnect) is assessed by examining the following: Assessment Objectives: - the network connection associated with a communications session is terminated at the end of the session or after [organization-defined parameter] of inactivity.

Control SC-7(20): SC-7(21) Policy and Procedures Separation of System and User Functionality INTERFACES FOR NON-PRIVILEGED USERS DISASSOCIABILITY Security Function Isolation HARDWARE SEPARATION ACCESS AND FLOW CONTROL FUNCTIONS MINIMIZE NONSECURITY FUNCTIONALITY MODULE COUPLING AND COHESIVENESS LAYERED STRUCTURES Information in Shared System Resources SECURITY LEVELS MULTILEVEL OR PERIODS PROCESSING Denial-of-Service Protection RESTRICT ABILITY TO ATTACK OTHER SYSTEMS CAPACITY, BANDWIDTH, AND REDUNDANCY DETECTION AND MONITORING Resource Availability Boundary Protection PHYSICALLY SEPARATED SUBNETWORKS PUBLIC ACCESS ACCESS POINTS EXTERNAL TELECOMMUNICATIONS SERVICES DENY BY DEFAULT · ALLOW BY EXCEPTION RESPONSE TO RECOGNIZED FAILURES SPLIT TUNNELING FOR REMOTE

DEVICES ROUTE TRAFFIC TO AUTHENTICATED PROXY SERVERS RESTRICT THREATENING OUTGOING COMMUNICATIONS
 TRAFFIC PREVENT EXFILTRATION RESTRICT INCOMING COMMUNICATIONS TRAFFIC HOST-BASED PROTECTION
 ISOLATION OF SECURITY TOOLS, MECHANISMS, AND SUPPORT COMPONENTS PROTECT AGAINST UNAUTHORIZED
 PHYSICAL CONNECTIONS NETWORKED PRIVILEGED ACCESSES PREVENT DISCOVERY OF SYSTEM COMPONENTS AUTOMA
 ENFORCEMENT OF PROTOCOL FORMATS FAIL SECURE BLOCK COMMUNICATION FROM NON-ORGANIZATIONALLY CONFIGU
 HOSTS DYNAMIC ISOLATION AND SEGREGATION ISOLATION OF SYSTEM COMPONENTS O S S S S S O/S O/S O/S S
 W: Incorporated into SC-4. S S S S S S W: Incorporated into SC-7. W: Incorporated into SC-7. S O S
 W: Incorporated into SC-7(18). S S S S S S S S S S S S O/S APPENDIX C
 PAGE 458 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV.

NIST SP 800-53 Rev 5 control SC-4.2 (Multilevel or Periods Processing) summarizes the requirements for this control: SC-4.2 · Multilevel or Periods Processing Control Statement: Prevent unauthorized information transfer via shared resources in accordance with [organization-defined parameter] when system processing explicitly switches between different information classification levels or security categories. Supplemental Guidance: Prevent unauthorized information transfer via shared resources in accordance with [organization-defined parameter] when system processing explicitly switches between different info

NIST SP 800-53 Rev 5 control SC-30.3 (Change Processing and Storage Locations) is defined as follows: SC-30.3 · Change Processing and Storage Locations Control Statement: Change the location of [organization-defined parameter] [organization-defined parameter]]. Supplemental Guidance: Change the location of [organization-defined parameter] [organization-defined parameter]]. Adversaries target critical mission and business functions and the systems that support those mission and business functions while also trying to minimize the exposure of their existence and tradecraft. The static, homogeneous, and deterministic nature of organizational systems targeted by adversaries make such systems mor

NIST SP 800-53 Rev 5 control SC-32 (System Partitioning) is assessed by examining, interviewing, and testing: SC-32 · System Partitioning Control Statement: Partition the system into [organization-defined parameter] residing in separate [organization-defined parameter] domains or environments based on [organization-defined parameter]. Supplemental Guidance: Partition the system into [organization-defined parameter] residing in separate [organization-defined parameter] domains or environments based on [organization-defined parameter]. System partitioning is part of a defense-in-depth protection strateg

Under the FedRAMP High baseline, SC-12.1 (SC-12.1 Availability): FedRAMP High Baseline · SC-12.1 · Availability Control Statement: Maintain availability of information in the event of the loss of cryptographic keys by users. Supplemental Guidance: Maintain availability of information in the event of the loss of cryptographic keys by users. Escrowing of encryption keys is a common practice for ensuring availability in the event of key loss. A forgotten passphrase is an example of losing a cryptographic key. Assessment Objectives: Maintain availability of in

NIST SP 800-171 Rev 3 control 03.13.08 (03.13.08 Transmission and Storage Confidentiality) is assessed by examining the following: Assessment Objectives: - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI during transmission. - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI while in storage.

Under the FedRAMP High baseline, SC-7.7 (SC-7.7 Split Tunneling for Remote Devices): FedRAMP High Baseline · SC-7.7 · Split Tunneling for Remote Devices Control Statement: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [organization-defined parameter]. Supplemental Guidance: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [organization-defined parameter]. Split tunneling is the process of allowing a remote

NIST SP 800-53 Rev 5 control SC-18 (Mobile Code) is assessed by examining, interviewing, and testing: SC-18 · Mobile Code Control Statement: a. Define acceptable and unacceptable mobile code and mobile code technologies; and b. Authorize, monitor, and control the use of mobile code within the system. Supplemental Guidance: a. Define acceptable and unacceptable mobile code and mobile

code technologies; and b. Authorize, monitor, and control the use of mobile code within the system. Mobile code includes any program, application, or content that can be transmitted across a network (e.g., embedded

NIST SP 800-53 Rev 5 control SC-15 (Collaborative Computing Devices and Applications) is assessed by examining, interviewing, and testing: SC-15 · Collaborative Computing Devices and Applications Control Statement: a. Prohibit remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter] ; and b. Provide an explicit indication of use to users physically present at the devices. Supplemental Guidance: a. Prohibit remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter] ; and b. Provide

Control SC-28: tion at rest cannot otherwise be achieved, organizations may employ other controls, including frequent scanning to identify malicious code at rest and secure offline storage in lieu of online storage. Related Controls: AC-3, AC-4, AC-6, AC-19, CA-7, CM-3, CM-5, CM-6, CP-9, MP-4, MP-5, PE-3, SC- 8, SC-12, SC-13, SC-34, SI-3, SI-7, SI-16. Control Enhancements: (1) PROTECTION OF INFORMATION AT REST | CRYPTOGRAPHIC PROTECTION Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [Assignment: organization-defined system components or media]: [Assignment: organization-defined information]. Discussion: The selection of cryptographic mechanisms is based on the need to protect the confidentiality and integrity of organizational information. The strength of mechanism is commensurate with the security category or classification of the information. Organizations have the flexibility to encrypt information on system components or media or encrypt data structures, including files, records, or fields. Related Controls: AC-19, SC-12, SC-13. (2) PROTECTION OF INFORMATION AT REST | OFFLINE STORAGE Remove the following information from online storage and store offline in a secure location: [Assignment: organization-defined information]. Discussion: Removing organizational information from online storage to offline storage eliminates the possibility of individuals gaining unauthorized access to the information through a network. Therefore, organizations may choose to move information to offline storage in lieu of protecting such information in online storage. Related Controls: None. (3) PROTECTION OF INFORMATION AT REST | CRYPTOGRAPHIC KEYS Provide protected storage for cryptographic keys [Selection: [Assignment: organization- defined safeguards]; hardware-protected key store].

NIST SP 800-53 Rev 5 control SC-28.3 (Cryptographic Keys) summarizes the requirements for this control: SC-28.3 · Cryptographic Keys Control Statement: Provide protected storage for cryptographic keys [organization-defined parameter]. Supplemental Guidance: Provide protected storage for cryptographic keys [organization-defined parameter]. A Trusted Platform Module (TPM) is an example of a hardware-protected data store that can be used to protect cryptographic keys.

SC.L2-3.13.13 · Mobile Code CMMC Assessment Guide · Level 2 | Version 2.13 239 FURTHER DISCUSSION Ensure mobile code is authorized to execute in company systems only in accordance with policy and technical configuration, and that unauthorized mobile code is not. Monitor the use of mobile code through boundary devices (e.g., firewalls), audit logs, or security utilities (e.g., mobile device management, advanced endpoint protection) and implement remediation activities as needed. The first intent of this requirement is to ensure the limits of mobile code usage and usage restrictions are documented and enforced. This includes documenting all authorizations for the use of mobile code and ensuring it is not used in other ways . Usage restrictions and implementation guidance apply to the selection and use of mobile code installed on servers and mobile code downloaded and executed on individual workstations and devices to include all mobile devices and smart phones. The second intent is to monitor the use of mobile code and implement remediation steps if its use does not align with policy. Example Your company has decided to prohibit the use of Flash, ActiveX, and Java plug -ins for web browsers on all of its computers [a]. To enforce this policy you configure the computer baseline configuration to disable and deny the execution of mobile code [a]. You implement an exception process to re- enable mobile code execution only for those users with a legitimate business need [a]. One department complains that a web application they need to perform their job no longer works. You meet with them and verify that the web application uses ActiveX in the browser. You submit a change request with the Change Review Board . Once the change is approved, you reconfigure the department's computers to allow the running of ActiveX in the browser. You also configure the company firewall to alert you if ActiveX is used by any website but the allowed one [b]. You set a reminder for yourself to check in with the

department at the end of the year to verify they still need that web application. Potential Assessment Considerations · Are there defined limits of mobile code usage and established usage restrictions, which specifically authorize use of mobile code (e.g., Java, JavaScript, ActiveX, PDF, Flash, Shockwave, Postscript, VBScript) within the information system [a]? · Is the use of mobile code documented, monitored, and managed (e.g., Java, JavaScript, ActiveX, PDF, Flash, Shockwave, Postscript, VBScript) [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.13.13

NIST SP 800-53 Rev 5 control SC-42.2 (Authorized Use) summarizes the requirements for this control: SC-42.2 · Authorized Use Control Statement: Employ the following measures so that data or information collected by [organization-defined parameter] is only used for authorized purposes: [organization-defined parameter]. Supplemental Guidance: Employ the following measures so that data or information collected by [organization-defined parameter] is only used for authorized purposes: [organization-defined parameter]. Information collected by sensors for a specific authorized purpose could be mis

NIST SP 800-53 Rev 5 control SC-39 (Process Isolation) summarizes the requirements for this control: SC-39 · Process Isolation Control Statement: Maintain a separate execution domain for each executing system process. Supplemental Guidance: Maintain a separate execution domain for each executing system process. Systems can maintain separate execution domains for each executing process by assigning each process a separate address space. Each system process has a distinct address space so that communication between processes is performed in a manner controlled through the security functions, an

NIST SP 800-171 Rev 3 control 03.13.12 (03.13.12 Collaborative Computing Devices and Applications) is assessed by examining the following: Assessment Objectives: - the remote activation of collaborative computing devices and applications is prohibited with the following exceptions: [organization-defined parameter]. - an explicit indication of use is provided to users who are physically present at the devices.

Control MA-1: trols: SC-8, SC-12, SC-13. (7) NONLOCAL MAINTENANCE | DISCONNECT VERIFICATION Verify session and network connection termination after the completion of nonlocal maintenance and diagnostic sessions. Discussion: Verifying the termination of a connection once maintenance is completed ensures that connections established during nonlocal maintenance and diagnostic sessions have been terminated and are no longer available for use. Related Controls: AC-12. References: [FIPS 140-3], [FIPS 197], [FIPS 201-2], [SP 800-63-3], [SP 800-88].

NIST SP 800-171 Rev 3 control 03.13.10 (03.13.10 Cryptographic Key Establishment and Management) is assessed by examining the following: Assessment Objectives: - cryptographic keys are established in the system in accordance with the following key management requirements: [organization-defined parameter]. - cryptographic keys are managed in the system in accordance with the following key management requirements: [organization-defined parameter].

NIST SP 800-171 Rev 3 control 03.13.13 (03.13.13 Mobile Code) requires organizations to implement the following: Control Statement: SR-03.13.13.a Define acceptable mobile code and mobile code technologies. SR-03.13.13.b Authorize, monitor, and control the use of mobile code. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.13.

NIST SP 800-171 Rev 3 control 03.13.13 (03.13.13 Mobile Code) is assessed by examining the following: Assessment Objectives: - the use of mobile code is authorized. - the use of mobile code is monitored. - the use of mobile code is controlled. - acceptable mobile code is defined. - acceptable mobile code technologies are defined.

NIST SP 800-53 Rev 5 control SC-31.2 (Maximum Bandwidth): SC-31.2 · Maximum Bandwidth Control Statement: Reduce the maximum bandwidth for identified covert [organization-defined parameter] channels to [organization-defined parameter]. Supplemental Guidance: Reduce the maximum bandwidth for identified covert [organization-defined parameter] channels to [organization-defined parameter]. The complete elimination of covert channels, especially covert timin

Under the FedRAMP High baseline, SC-28.1 (SC-28.1 Cryptographic Protection): FedRAMP High Baseline

· SC-28.1 · Cryptographic Protection Control Statement: Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of the following information at rest on [organization-defined parameter]: [organization-defined parameter]. The sel

NIST SP 800-53 Rev 5 control SC-23.3 (Unique System-generated Session Identifiers) summarizes the requirements for this control: SC-23.3 · Unique System-generated Session Identifiers Control Statement: Generate a unique session identifier for each session with [organization-defined parameter] and recognize only session identifiers that are system-generated. Supplemental Guidance: Generate a unique session identifier for each session with [organization-defined parameter] and recognize only session identifiers that are system-generated. Generating unique session identifiers curtails the ability of adversaries to reuse pre

NIST SP 800-53 Rev 5 control SC-16.2 (Anti-spoofing Mechanisms): SC-16.2 · Anti-spoofing Mechanisms Control Statement: Implement anti-spoofing mechanisms to prevent adversaries from falsifying the security attributes indicating the successful application of the security process. Supplemental Guidance: Implement anti-spoofing mechanisms to prevent adversaries from falsifying the security attributes indicating the successful application of the security process.

NIST SP 800-53 Rev 5 control SC-5.2 (Capacity, Bandwidth, and Redundancy) is assessed by examining, interviewing, and testing: SC-5.2 · Capacity, Bandwidth, and Redundancy Control Statement: Manage capacity, bandwidth, or other redundancy to limit the effects of information flooding denial-of-service attacks. Supplemental Guidance: Manage capacity, bandwidth, or other redundancy to limit the effects of information flooding denial-of-service attacks. Managing capacity ensures that sufficient capacity is available to counter flooding attacks. Managing capacity includes establishing selected usage priorities, quotas, par

NIST SP 800-53 Rev 5 control SC-31.1 (Test Covert Channels for Exploitability) summarizes the requirements for this control: SC-31.1 · Test Covert Channels for Exploitability Control Statement: Test a subset of the identified covert channels to determine the channels that are exploitable. Supplemental Guidance: Test a subset of the identified covert channels to determine the channels that are exploitable. None.

SC-37 · Out-of-band Channels Control Statement: Employ the following out-of-band channels for the physical delivery or electronic transmission of [organization-defined parameter] to [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Employ the following out-of-band channels for the physical delivery or electronic transmission of [organization-defined parameter] to [organization-defined parameter]: [organization-defined parameter]. Out-of-band channels include local, non-network accesses to systems; network paths physically separate from network paths used for operational traffic; or non-electronic paths, such as the U.S. Postal Service. The use of out-of-band channels is contrasted with the use of in-band channels (i.e., the same channels) that carry routine operational traffic. Out-of-band channels do not have the same vulnerability or exposure as in-band channels. Therefore, the confidentiality, integrity, or availability compromises of in-band channels will not compromise or adversely affect the out-of-band channels. Organizations may employ out-of-band channels in the delivery or transmission of organizational items, including authenticators and credentials; cryptographic key management information; system and data backups; configuration management changes for hardware, firmware, or software; security updates; maintenance information; and malicious code protection updates. For example, cryptographic keys for encrypted files are delivered using a different channel than the file.

NIST SP 800-53 Rev 5 control SC-37 (Out-of-band Channels) is assessed by examining, interviewing, and testing: SC-37 · Out-of-band Channels Control Statement: Employ the following out-of-band channels for the physical delivery or electronic transmission of [organization-defined parameter] to [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Employ the following out-of-band channels for the physical delivery or electronic transmission of [organization-defined parameter] to [organization-defined parameter]: [organization-defined parameter]. Out-of-band channels in

NIST SP 800-53 Rev 5 control SC-7.26 (Classified National Security System Connections) summarizes the requirements for this control: SC-7.26 · Classified National Security System Connections Control Statement: Prohibit the direct connection of a classified national security system to an external network without the use of [organization-defined parameter]. Supplemental Guidance: Prohibit the direct connection of a classified national security system to an external network without the use of [organization-defined parameter]. A direct connection is a dedicated physical or virtual connection between two or more systems. Organiz

SC-5 · Denial-of-service Protection Control Statement: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b. Employ the following controls to achieve the denial-of-service objective: [organization-defined parameter]. Supplemental Guidance: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b. Employ the following controls to achieve the denial-of-service objective: [organization-defined parameter]. Denial-of-service events may occur due to a variety of internal and external causes, such as an attack by an adversary or a lack of planning to support organizational needs with respect to capacity and bandwidth. Such attacks can occur across a wide range of network protocols (e.g., IPv4, IPv6). A variety of technologies are available to limit or eliminate the origination and effects of denial-of-service events. For example, boundary protection devices can filter certain types of packets to protect system components on internal networks from being directly affected by or the source of denial-of-service attacks. Employing increased network capacity and bandwidth combined with service redundancy also reduces the susceptibility to denial-of-service events.

NIST SP 800-53 Rev 5 control SC-48.1 (Dynamic Relocation of Sensors or Monitoring Capabilities) summarizes the requirements for this control: SC-48.1 · Dynamic Relocation of Sensors or Monitoring Capabilities Control Statement: Dynamically relocate [organization-defined parameter] to [organization-defined parameter] under the following conditions or circumstances: [organization-defined parameter]. Supplemental Guidance: Dynamically relocate [organization-defined parameter] to [organization-defined parameter] under the following conditions or circumstances: [organization-defined parameter]. None.

NIST SP 800-171 Rev 3 control 03.13.01 (03.13.01 Boundary Protection) is assessed by examining the following: Assessment Objectives: - communications at external managed interfaces to the system are monitored. - communications at external managed interfaces to the system are controlled. - communications at key internal managed interfaces within the system are monitored. - communications at key internal managed interfaces within the system are controlled. - subnetworks are implemented for publicly accessible system components that are physically or logically separated from internal networks. - external system connections are only made through managed interfaces that consist of boundary protection device

NIST SP 800-53 Rev 5 control SC-12.1 (Availability) summarizes the requirements for this control: SC-12.1 · Availability Control Statement: Maintain availability of information in the event of the loss of cryptographic keys by users. Supplemental Guidance: Maintain availability of information in the event of the loss of cryptographic keys by users. Escrowing of encryption keys is a common practice for ensuring availability in the event of key loss. A forgotten passphrase is an example of losing a cryptographic key.

Under the FedRAMP High baseline, SC-5 (SC-5 Denial-of-service Protection): FedRAMP High Baseline · SC-5 · Denial-of-service Protection Control Statement: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b. Employ the following controls to achieve the denial-of-service objective: [organization-defined parameter]. Supplemental Guidance: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b. Em

Control SC-2: trator privileges, are not available to the general user population. Restricting user access also prohibits the use of the grey-out option commonly used to eliminate accessibility to such information. One potential solution is to withhold system administration options until users establish sessions with administrator privileges. Related Controls: AC-3. (2) SEPARATION OF SYSTEM AND USER FUNCTIONALITY | DISASSOCIABILITY Store state information from applications and software

separately. Discussion: If a system is compromised, storing applications and software separately from state information about users' interactions with an application may better protect individuals' privacy. Related Controls: None. References: None.

Under the FedRAMP High baseline, SC-23 (SC-23 Session Authenticity): FedRAMP High Baseline · SC-23 · Session Authenticity Control Statement: Protect the authenticity of communications sessions. Supplemental Guidance: Protect the authenticity of communications sessions. Protecting session authenticity addresses communications protection at the session level, not at the packet level. Such protection establishes grounds for confidence at both ends of communications sessions in the ongoing identities of other parties and the validity of transmitted information. Aut

NIST SP 800-53 Rev 5 control SC-7.8 (Route Traffic to Authenticated Proxy Servers) is defined as follows: SC-7.8 · Route Traffic to Authenticated Proxy Servers Control Statement: Route [organization-defined parameter] to [organization-defined parameter] through authenticated proxy servers at managed interfaces. Supplemental Guidance: Route [organization-defined parameter] to [organization-defined parameter] through authenticated proxy servers at managed interfaces. External networks are networks outside of organizational control. A proxy server is a server (i.e., system or application) that acts as an intermediary for clients requesting system resources from non-organizational or other organizat

NIST SP 800-53 Rev 5 control SC-42 (Sensor Capability and Data) summarizes the requirements for this control: SC-42 · Sensor Capability and Data Control Statement: a. Prohibit [organization-defined parameter] ; and b. Provide an explicit indication of sensor use to [organization-defined parameter]. Supplemental Guidance: a. Prohibit [organization-defined parameter] ; and b. Provide an explicit indication of sensor use to [organization-defined parameter]. Sensor capability and data applies to types of systems or system components characterized as mobile devices, such as cellular telephones, smart phone

NIST SP 800-53 Rev 5 control SC-7.28 (Connections to Public Networks) is assessed by examining, interviewing, and testing: SC-7.28 · Connections to Public Networks Control Statement: Prohibit the direct connection of [organization-defined parameter] to a public network. Supplemental Guidance: Prohibit the direct connection of [organization-defined parameter] to a public network. A direct connection is a dedicated physical or virtual connection between two or more systems. A public network is a network accessible to the public, including the Internet and organizational extranets with public access.

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement enhances SP 800-171 requirement 03.13.01. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 PROTECTION STRATEGY 1937 P RA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: SC-07(13) 03.1 3.10E Sep arate Subnetworks Implement separate network addresses to connect to systems in different security domains. DISCUSSION The decomposition of systems into subnetworks (i.e., subnets) helps to provide the appropriate level of protection for network connections to different security domains. This requirement enhances SP 800-171 requirement 03.13.01. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Limit (Reduce) REFERENCES Source Control: SC-07(22)

NIST SP 800-53 Rev 5 control SC-32.1 (Separate Physical Domains for Privileged Functions) is assessed by examining, interviewing, and testing: SC-32.1 · Separate Physical Domains for Privileged Functions Control Statement: Partition privileged functions into separate physical domains. Supplemental Guidance: Partition privileged functions into separate physical domains. Privileged functions that operate in a single physical domain may represent a single point of failure if that domain becomes compromised or experiences a denial of service.

NIST SP 800-53 Rev 5 control SC-26 (Decoys) is assessed by examining, interviewing, and testing: SC-26 · Decoys Control Statement: Include components within organizational systems specifically designed to be the target of malicious attacks for detecting, deflecting, and analyzing such attacks. Supplemental Guidance: Include components within organizational systems specifically designed to be the target of malicious attacks for detecting, deflecting, and analyzing such attacks. Decoys (i.e., honeypots, honeynets, or deception nets) are established to attract adversaries and deflect attacks

FedRAMP Moderate Baseline · SC-15 · Collaborative Computing Devices and Applications Control Statement: a. Prohibit remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter] ; and b. Provide an explicit indication of use to users physically present at the devices. Supplemental Guidance: a. Prohibit remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter] ; and b. Provide an explicit indication of use to users physically present at the devices. Collaborative computing devices and applications include remote meeting devices and applications, networked white boards, cameras, and microphones. The explicit indication of use includes signals to users when collaborative computing devices and applications are activated. Assessment Objectives: a. Prohibit remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter] ; and b. Provide an explicit indication of use to users physically present at the devices. FedRAMP Parameter Values: sc-15_odp: no exceptions for computing devices

Under the FedRAMP High baseline, SC-45.1 (SC-45.1 Synchronization with Authoritative Time Source): FedRAMP High Baseline · SC-45.1 · Synchronization with Authoritative Time Source Control Statement: (a) Compare the internal system clocks [organization-defined parameter] with [organization-defined parameter] ; and (b) Synchronize the internal system clocks to the authoritative time source when the time difference is greater than [organization-defined parameter]. Supplemental Guidance: (a) Compare the internal system clocks [organization-defined parameter] with [organization-defined parameter]

NIST SP 800-53 Rev 5 control SC-7.9 (Restrict Threatening Outgoing Communications Traffic) is assessed by examining, interviewing, and testing: SC-7.9 · Restrict Threatening Outgoing Communications Traffic Control Statement: (a) Detect and deny outgoing communications traffic posing a threat to external systems; and (b) Audit the identity of internal users associated with denied communications. Supplemental Guidance: (a) Detect and deny outgoing communications traffic posing a threat to external systems; and (b) Audit the identity of internal users associated with denied communications. Detecting outgoing communications traffic from i

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: System and Communications Protection 3.13.11 Cryptography for Confidentiality of CUI Implement the following types of cryptography to protect the confidentiality of CUI: [Assignment: organization-defined types of cryptography] (03.13.11). Related Controls: SC-13 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.13.11 [Assignment: organization- defined types of cryptography] FIPS Validated Cryptography (<https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program/Validated-Modules>) System and Communications Protection 3.13.12 Remote Activation of Collaborative Computing Devices a. Prohibit the remote activation of collaborative computing devices and applications with the following exceptions: [Assignment: organization-defined exceptions where remote a

NIST SP 800-53 Rev 5 control SC-35 (External Malicious Code Identification) is defined as follows: SC-35 · External Malicious Code Identification Control Statement: Include system components that proactively seek to identify network-based malicious code or malicious websites. Supplemental Guidance: Include system components that proactively seek to identify network-based malicious code or malicious websites. External malicious code identification differs from decoys in [SC-26](#sc-26) in that the components actively probe networks, including the Internet, in search of malicious code contained on external websites. Like decoys, the use of external malicious code identification techniques r

NIST SP 800-53 Rev 5 control SC-30.2 (Randomness) summarizes the requirements for this control: SC-30.2 · Randomness Control Statement: Employ [organization-defined parameter] to introduce randomness into organizational operations and assets. Supplemental Guidance: Employ [organization-defined parameter] to introduce randomness into organizational operations and assets. Randomness introduces increased levels of uncertainty for adversaries regarding the actions that organizations take to defend their systems against attacks. Such actions may impede the ability of adversaries to correctly

NIST SP 800-171 Rev 3 control 03.13.13 (03.13.13 Mobile Code) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2

assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

and (b) Take the following actions in response to identified faults, errors, or compromises: [Assignment: organization-defined actions]. Discussion: Distributed processing and/or storage may be used to reduce opportunities for adversaries to compromise the confidentiality, integrity, or availability of organizational information and systems. However, the distribution of processing and storage components does not prevent adversaries from compromising one or more of the components. Polling compares the processing results and/or storage content from the distributed components and subsequently votes on the outcomes. Polling identifies potential faults, compromises, or errors in the distributed processing and storage components. Related Controls: SI-4.

NIST SP 800-53 Rev 5 control SC-7.11 (Restrict Incoming Communications Traffic) summarizes the requirements for this control: SC-7.11 · Restrict Incoming Communications Traffic Control Statement: Only allow incoming communications from [organization-defined parameter] to be routed to [organization-defined parameter]. Supplemental Guidance: Only allow incoming communications from [organization-defined parameter] to be routed to [organization-defined parameter]. General source address validation techniques are applied to restrict the use of illegal and unallocated source addresses as well as source addresses that should

Control SC-15: ants carry out the disconnect activity without having to go through complex and tedious procedures. Disconnect from collaborative computing devices can be manual or automatic. Related Controls: None. (2) COLLABORATIVE COMPUTING DEVICES | BLOCKING INBOUND AND OUTBOUND COMMUNICATIONS TRAFFIC [Withdrawn: Incorporated into SC-7.] (3) COLLABORATIVE COMPUTING DEVICES | DISABLING AND REMOVAL IN SECURE WORK AREAS Disable or remove collaborative computing devices and applications from [Assignment: organization-defined systems or system components] in [Assignment: organization-defined secure work areas]. Discussion: Failing to disable or remove collaborative computing devices and applications from systems or system components can result in compromises of information, including eavesdropping on conversations. A Sensitive Compartmented Information Facility (SCIF) is an example of a secure work area. Related Controls: None. (4) COLLABORATIVE COMPUTING DEVICES | EXPLICITLY INDICATE CURRENT PARTICIPANTS Provide an explicit indication of current participants in [Assignment: organization-defined online meetings and teleconferences]. Discussion: Explicitly indicating current participants prevents unauthorized individuals from participating in collaborative computing sessions without the explicit knowledge of other participants. Related Controls: None. References: None.

FedRAMP Moderate Baseline · SC-7.5 · Deny by Default · Allow by Exception Control Statement: Deny network communications traffic by default and allow network communications traffic by exception [organization-defined parameter]. Supplemental Guidance: Deny network communications traffic by default and allow network communications traffic by exception [organization-defined parameter]. Denying by default and allowing by exception applies to inbound and outbound network communications traffic. A deny-all, permit-by-exception network communications traffic policy ensures that only those system connections that are essential and approved are allowed. Deny by default, allow by exception also applies to a system that is connected to an external system. Assessment Objectives: Deny network communications traffic by default and allow network communications traffic by exception [organization-defined parameter]. FedRAMP Parameter Values: sc-07.05_odp.01: any systems sc-07.05_odp.02: systems for which network communications traffic is denied by default and network communications traffic is allowed by exception are defined (if selected).

NIST SP 800-53 Rev 5 control SC-15.3 (Disabling and Removal in Secure Work Areas) summarizes the requirements for this control: SC-15.3 · Disabling and Removal in Secure Work Areas Control Statement: Disable or remove collaborative computing devices and applications from [organization-defined parameter] in [organization-defined parameter]. Supplemental Guidance: Disable or remove collaborative computing devices and applications from [organization-defined parameter] in [organization-defined parameter]. Failing to disable or remove collaborative computing devices and applications from systems or system components can res

NIST SP 800-53 Rev 5 control SC-18.1 (Identify Unacceptable Code and Take Corrective Actions) is assessed by examining, interviewing, and testing: SC-18.1 · Identify Unacceptable Code and Take

Corrective Actions Control Statement: Identify [organization-defined parameter] and take [organization-defined parameter]. Supplemental Guidance: Identify [organization-defined parameter] and take [organization-defined parameter]. Corrective actions when unacceptable mobile code is detected include blocking, quarantine, or alerting administrators. Blocking includes preventing the transmission of word processing files with embedded macros when such

and (b) Monitor the following system resources to determine if sufficient resources exist to prevent effective denial-of-service attacks: [Assignment: organization-defined system resources]. CHAPTER THREE PAGE 296 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV.

SC-6 · Resource Availability Control Statement: Protect the availability of resources by allocating [organization-defined parameter] by [organization-defined parameter]. Supplemental Guidance: Protect the availability of resources by allocating [organization-defined parameter] by [organization-defined parameter]. Priority protection prevents lower-priority processes from delaying or interfering with the system that services higher-priority processes. Quotas prevent users or processes from obtaining more than predetermined amounts of resources.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Limit (Reduce) REFERENCES Source Control: SC-07(21) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.13.05E Change Processing and Storage Locations 1839

NIST SP 800-53 Rev 5 control SC-40 (Wireless Link Protection) summarizes the requirements for this control: SC-40 · Wireless Link Protection Control Statement: Protect external and internal [organization-defined parameter] from the following signal parameter attacks: [organization-defined parameter]. Supplemental Guidance: Protect external and internal [organization-defined parameter] from the following signal parameter attacks: [organization-defined parameter]. Wireless link protection applies to internal and external wireless communication links that may be visible to individuals who are not autho

Under the FedRAMP Moderate baseline, SC-5 (SC-5 Denial-of-service Protection): FedRAMP Moderate Baseline · SC-5 · Denial-of-service Protection Control Statement: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b. Employ the following controls to achieve the denial-of-service objective: [organization-defined parameter]. Supplemental Guidance: a. [organization-defined parameter] the effects of the following types of denial-of-service events: [organization-defined parameter] ; and b

NIST SP 800-53 Rev 5 control SC-7.19 (Block Communication from Non-organizationally Configured Hosts): SC-7.19 · Block Communication from Non-organizationally Configured Hosts Control Statement: Block inbound and outbound communications traffic between [organization-defined parameter] that are independently configured by end users and external service providers. Supplemental Guidance: Block inbound and outbound communications traffic between [organization-defined parameter] that are independently

NIST SP 800-53 Rev 5 control SC-18.4 (Prevent Automatic Execution) summarizes the requirements for this control: SC-18.4 · Prevent Automatic Execution Control Statement: Prevent the automatic execution of mobile code in [organization-defined parameter] and enforce [organization-defined parameter] prior to executing the code. Supplemental Guidance: Prevent the automatic execution of mobile code in [organization-defined parameter] and enforce [organization-defined parameter] prior to executing the code. Actions enforced before executing mobile code include prompting users prior to opening email attachments

NIST SP 800-53 Rev 5 control SC-2.2 (Disassociability): SC-2.2 · Disassociability Control Statement: Store state information from applications and software separately. Supplemental Guidance: Store state information from applications and software separately. If a system is compromised, storing applications and software separately from state information about users· interactions with an application may better protect individuals· privacy.

SC-15 · Collaborative Computing Devices and Applications Control Statement: a. Prohibit remote

activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter] ; and b. Provide an explicit indication of use to users physically present at the devices. Supplemental Guidance: a. Prohibit remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter] ; and b. Provide an explicit indication of use to users physically present at the devices. Collaborative computing devices and applications include remote meeting devices and applications, networked white boards, cameras, and microphones. The explicit indication of use includes signals to users when collaborative computing devices and applications are activated.

SC-8.4 · Conceal or Randomize Communications Control Statement: Implement cryptographic mechanisms to conceal or randomize communication patterns unless otherwise protected by [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to conceal or randomize communication patterns unless otherwise protected by [organization-defined parameter]. Concealing or randomizing communication patterns addresses protection from unauthorized disclosure of information. Communication patterns include frequency, periods, predictability, and amount. Changes to communications patterns can reveal information with intelligence value, especially when combined with other available information related to the mission and business functions of the organization. Concealing or randomizing communications prevents the derivation of intelligence based on communications patterns and applies to both internal and external networks or links that may be visible to individuals who are not authorized users. Encrypting the links and transmitting in continuous, fixed, or random patterns prevents the derivation of intelligence from the system communications patterns. Alternative physical controls include protected distribution systems.

Under the FedRAMP Moderate baseline, SC-8 (SC-8 Transmission Confidentiality and Integrity): FedRAMP Moderate Baseline · SC-8 · Transmission Confidentiality and Integrity Control Statement: Protect the [organization-defined parameter] of transmitted information. Supplemental Guidance: Protect the [organization-defined parameter] of transmitted information. Protecting the confidentiality and integrity of transmitted information applies to internal and external networks as well as any system components that can transmit information, including servers, notebook computers, desktop compute

The government cannot comment on the suitability of specific implementations or products to meet CMMC security requirements and is aware that FIPS module validation can exceed the 180-day CMMC assessment POA&M threshold. Guidance regarding FIPS implementation on Windows 11 is not appropriate for inclusion in the rule text and DoD declines to make an update. Limitations of the FIPS-validated module process do not impact the implementation status of FIPS cryptography. The rule has been updated to include enduring exceptions and temporary deficiencies. Vendor (printed page 83131) limitations with respect to FIPS validation could be considered enduring exceptions or temporary deficiencies and should be addressed in an OSA's operational plan of action. Several requirements within NIST SP 800-171 R2 specify the use of encryption without consideration of the processing, storage, or transmission of CUI. Requirement 3.13.11 requires that the encryption used be a FIPS-validated module if the encryption is used to protect the confidentiality of CUI. The scoring in §·170.24(c)(2)(i)(B)(4)(ii) is based on the use of encryption and whether the encryption uses a FIPS-validated module. There is no consideration for multiple layers of encryption so specific guidance to assessors regarding layers of encryption is not needed and DoD declines to make the suggested addition. OSAs may choose how they implement security requirements and C3PAOs will assess based on the stated implementations. CCAs are trained in the correct process to assess security requirements. The DoD has updated the rule text at §· 170.24(c) to clarify which requirements may be included on a POA&M, which addresses the error in the point value for encryption. The scoring for CMMC Level 3 is separate from the scoring for CMMC Level 2. As stated in §·170.24(c)(3), the CMMC Level 3 assessment score is equal to the number of CMMC Level 3 security requirements that are assessed as MET. There are twenty-four CMMC Level 3 security requirements, identified in table 1 to §·170.14(c)(4). CMMC Level 3 POA&M eligibility is based on the number of CMMC Level 3 security requirements and does NOT include the 110 CMMC Level 2 requirements.

NIST SP 800-53 Rev 5 control SC-12.2 (Symmetric Keys) summarizes the requirements for this control: SC-12.2 · Symmetric Keys Control Statement: Produce, control, and distribute symmetric cryptographic keys using [organization-defined parameter] key management technology and processes. Supplemental Guidance: Produce, control, and distribute symmetric cryptographic keys using [organization-defined parameter] key management technology and processes. [SP

800-56A)(#20957dbb-6a1e-40a2-b38a-66f67d33ac2e), [SP 800-56B](#0d083d8a-5cc6-46f1-8d79-3081d42bcb75), and [SP 800-56C](#eef62b16-c796-4554-955

logically] between the physical and/or network interfaces for the connecting security domains.

Discussion: For logical policy enforcement mechanisms, organizations avoid creating a logical path between interfaces to prevent the ability to bypass the policy enforcement mechanism. For physical policy enforcement mechanisms, the robustness of physical isolation afforded by the physical implementation of policy enforcement to preclude the presence of logical covert channels penetrating the security domain may be needed. Contact ncdsmo@nsa.gov for more information. Related Controls: AC-4, SC-7. Control Enhancements: None. References: [SP 800-160-1].

NIST SP 800-171 Rev 3 control 03.13.15 (03.13.15 Session Authenticity) requires organizations to implement the following: 03.13.15 · Session Authenticity Supplemental Guidance: Protecting session authenticity addresses communications protection at the session level, not at the packet level. Such protection establishes grounds for confidence at both ends of the communications sessions in the ongoing identities of other parties and the validity of the transmitted information. Authenticity protection includes protecting against adversary-in-the-middle attacks, session hijacking, and the insertion of false information For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.15.

Under the FedRAMP High baseline, SC-7.21 (SC-7.21 Isolation of System Components): FedRAMP High Baseline · SC-7.21 · Isolation of System Components Control Statement: Employ boundary protection mechanisms to isolate [organization-defined parameter] supporting [organization-defined parameter]. Supplemental Guidance: Employ boundary protection mechanisms to isolate [organization-defined parameter] supporting [organization-defined parameter]. Organizations can isolate system components that perform different mission or business functions. Such isolation limits unauthorized info

) Basic Security Requirements: AC.L2-3.1.1, AC.L2-3.1.2, AT.L2-3.2.1, AT.L2-3.2.2, AU.L2-3.3.1, CM.L2-3.4.1, CM.L2-3.4.2, IA.L2-3.5.1, IA.L2-3.5.2, IR.L2-3.6.1, IR.L2-3.6.2, MA.L2-3.7.2, MP.L2-3.8.3, PS.L2-3.9.2, PE.L2-3.10.1, PE.L2-3.10.2, CA.L2-3.12.1, CA.L2-3.12.3, SC.L2-3.13.1, SC.L2-3.13.2, SI.L2-3.14.1, SI.L2-3.14.2, and SI.L2-3.14.3. (ii) Derived Security Requirements: AC.L2-3.1.12, AC.L2-3.1.13, AC.L2-3.1.16, AC.L2-3.1.17, AC.L2-3.1.18, AU.L2-3.3.5, CM.L2-3.4.5, CM.L2-3.4.6, CM.L2-3.4.7, CM.L2-3.4.8, IA.L2-3.5.10, MA.L2-3.7.5, MP.L2-3.8.7, RA.L2-3.11.2, SC.L2-3.13.5, SC.L2-3.13.6, SC.L2-3.13.15, SI.L2-3.14.4, and SI.L2-3.14.6. (2) For Basic and Derived Security Requirements that, if not implemented, have a specific and confined effect on the security of the network and its data, 3 points are subtracted from the maximum score. The Basic and Derived security requirements with a value of 3 points include: (i) Basic Security Requirements: AU.L2-3.3.2, MA.L2-3.7.1, MP.L2-3.8.1, MP.L2-3.8.2, PS.L2-3.9.1, RA.L2-3.11.1, and CA.L2-3.12.2. (ii) Derived Security Requirements: AC.L2-3.1.5, AC.L2-3.1.19, MA.L2-3.7.4, MP.L2-3.8.8, SC.L2-3.13.8, SI.L2-3.14.5, and SI.L2-3.14.7. (3) All remaining Derived Security Requirements, other than the exceptions noted, if not implemented, have a limited or indirect effect on the security of the network and its data. For these, 1 point is subtracted from the maximum score. (4) Two Derived Security Requirements can be partially effective even if not completely or properly implemented, and the points deducted may be adjusted depending on how the security requirement is implemented. (i) Multi-factor authentication (MFA) (CMMC Level 2 security requirement IA.L2-3.5.3) is typically implemented first for remote and privileged users (since these users are both limited in number and more critical) and then for the general user, so three (3) points are subtracted from the maximum score if MFA is implemented only for remote and privileged users. Five (5) points are subtracted from the maximum score if MFA is not implemented for any users. (ii) FIPS-validated encryption (CMMC Level 2 security requirement SC.L2-3.13.11) is required to protect the confidentiality of CUI. If encryption is employed, but is not FIPS-validated, three (3) points are subtracted from the maximum score; if encryption is not employed, five (5) points are subtracted from the maximum score. (5) Future revisions of NIST SP 800-171 Rev 2 may add, delete, or substantively revise security requirements. When this occurs, a value is assigned by the Department to any new or modified security requirements in accordance with the scoring methodology in accordance with paragraph (c) of this section.

NIST SP 800-53 Rev 5 control SC-16.3 (Cryptographic Binding) is assessed by examining, interviewing, and testing: SC-16.3 · Cryptographic Binding Control Statement: Implement [organization-defined

parameter] to bind security and privacy attributes to transmitted information. Supplemental Guidance: Implement [organization-defined parameter] to bind security and privacy attributes to transmitted information. Cryptographic mechanisms and techniques can provide strong security and privacy attribute binding to transmitted information to help ensure the integrity of such information.

NIST SP 800-53 Rev 5 control SC-37.1 (Ensure Delivery and Transmission) is assessed by examining, interviewing, and testing: SC-37.1 · Ensure Delivery and Transmission Control Statement: Employ [organization-defined parameter] to ensure that only [organization-defined parameter] receive the following information, system components, or devices: [organization-defined parameter]. Supplemental Guidance: Employ [organization-defined parameter] to ensure that only [organization-defined parameter] receive the following information, system components, or devices: [organization-defined parameter]. Techniques employed by orga

detect changes to information] during transmission. Discussion: The purpose of a protected distribution system is to deter, detect, and/or make difficult physical access to the communication lines that carry national security information. Related Controls: None. References: [FIPS 140-3], [FIPS 197], [SP 800-52], [SP 800-77], [SP 800-81-2], [SP 800-113], [SP 800-177], [IR 8023].

NIST SP 800-53 Rev 5 control SC-2 (Separation of System and User Functionality) is assessed by examining, interviewing, and testing: SC-2 · Separation of System and User Functionality Control Statement: Separate user functionality, including user interface services, from system management functionality. Supplemental Guidance: Separate user functionality, including user interface services, from system management functionality. System management functionality includes functions that are necessary to administer databases, network components, workstations, or servers. These functions typically require privileged user access. Th

NIST SP 800-53 Rev 5 control SC-7.13 (Isolation of Security Tools, Mechanisms, and Support Components) is defined as follows: SC-7.13 · Isolation of Security Tools, Mechanisms, and Support Components Control Statement: Isolate [organization-defined parameter] from other internal system components by implementing physically separate subnetworks with managed interfaces to other components of the system. Supplemental Guidance: Isolate [organization-defined parameter] from other internal system components by implementing physically separate subnetworks with managed interfaces to other components of the system. Physically separate subnetworks with managed interfaces are useful in isolating computer network defenses from

NIST SP 800-171 Rev 3 control 03.13.06 (03.13.06 Network Communications · Deny by Default · Allow by Exception) is assessed by examining the following: Assessment Objectives: - network communications traffic is denied by default. - network communications traffic is allowed by exception.

Under the FedRAMP Moderate baseline, SC-13 (SC-13 Cryptographic Protection): FedRAMP Moderate Baseline · SC-13 · Cryptographic Protection Control Statement: a. Determine the [organization-defined parameter] ; and b. Implement the following types of cryptography required for each specified cryptographic use: [organization-defined parameter]. Supplemental Guidance: a. Determine the [organization-defined parameter] ; and b. Implement the following types of cryptography required for each specified cryptographic use: [organization-defined parameter]. Cryptography can be emp

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 REQUIREMENT NUMBER ENHANCED SECURITY REQUIREMENT REQUIREMENT TYPE 03.13.06E Platform-Independent Applications S SP 800-53, SC-27 03.13.07E Virtualization Techniques S SP 800-53, SC-29(01) 03.13.08E Decoys S SP 800-53, SC-26 03.13.09E Isolation of Security Tool, Mechanism, and Support Component E 03.13.01 03.13.10E Separate Subnetworks E 03.13.01 03.13.11E Thin Nodes S SP 800-53, SC-25 03.13.12E Denial-of-Service Protection T SP 800-53, SC-05 03.13.13E Port and Input/Output Device Access S SP 800-53, SC-41 03.13.14E Detonation Chambers S SP 800-53, SC-44 03.13.15E Separate Subnets to Isolate System Components and Functions E 03.13.01 03.13.16E System Partitioning

NIST SP 800-53 Rev 5 control SC-39.2 (Separate Execution Domain Per Thread) summarizes the requirements for this control: SC-39.2 · Separate Execution Domain Per Thread Control Statement: Maintain a separate execution domain for each thread in [organization-defined parameter].

Supplemental Guidance: Maintain a separate execution domain for each thread in [organization-defined parameter]. None.

NIST SP 800-171 Rev 3 control 03.13.12 (03.13.12 Collaborative Computing Devices and Applications) requires organizations to implement the following: Control Statement: SR-03.13.12.a Prohibit the remote activation of collaborative computing devices and applications with the following exceptions: [organization-defined parameter]. SR-03.13.12.b Provide an explicit indication of use to users physically present at the devices. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.13.12.

NIST SP 800-53 Rev 5 control SC-39.2 (Separate Execution Domain Per Thread) is assessed by examining, interviewing, and testing: SC-39.2 · Separate Execution Domain Per Thread Control Statement: Maintain a separate execution domain for each thread in [organization-defined parameter]. Supplemental Guidance: Maintain a separate execution domain for each thread in [organization-defined parameter]. None.

SC.L2-3.13.8 · Data in Transit CMMC Assessment Guide · Level 2 | Version 2.13 228
confidentiality. In such situations, organizations determine what types of confidentiality services are available in commercial telecommunication service packages. If it is infeasible or impractical to obtain the necessary safeguards and assurances of the effectiveness of the safeguards through appropriate contracting vehicles, organizations implement compensating safeguards or explicitly accept the additional risk. An example of an alternative physical safeguard is a protected distribution system (PDS) where the distribution medium is protected against electronic or physical intercept, thereby ensuring the confidentiality of the information being transmitted. FURTHER DISCUSSION The intent of this requirement is to ensure CUI is cryptographically protected during transit, particularly on the internet. The most common way to accomplish this is to establish a TLS tunnel between the source and destination using the most current version of TLS. This requirement does not specify a mutually authenticated handshake, but mutual authentication is the most secure approach to creating a tunnel. Because the use of cryptography in this requirement is to protect the confidentiality of CUI, the cryptography used must meet the criteria specified in requirement SC.L2-3.13.11. This requirement, SC.L2-3.13.8, requires cryptographic mechanisms be used to prevent the disclosure of CUI in-transit and leverages SC.L2-3.13.11, which specifies that the algorithms used must be FIPS-validated cryptography. Example You are a system administrator responsible for configuring encryption on all devices that contain CUI. Because your users regularly store CUI on laptops and take them out of the office, you encrypt the hard drives with a FIPS -validated encryption tool built into the operating system. For users who need to share CUI, you install a Secure FTP server to allow CUI to be transmitted in a compliant manner [a]. You verify that the server is using a FIPS- validated encryption module by checking the NIST Cryptographic Module Validation Program website [c]. You turn on the ·FIPS Compliance· setting for the server during configuration because that is what is required for this product in order to use only FIPS -validated cryptography [c]. Potential Assessment Considerations · Are cryptographic mechanisms used to prevent unauthorized disclosure of information during transmission unless otherwise protected by alternative physical measures (e.g., PDS) [c]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.13.8

NIST SP 800-53 Rev 5 control SC-20.2 (Data Origin and Integrity) is assessed by examining, interviewing, and testing: SC-20.2 · Data Origin and Integrity Control Statement: Provide data origin and integrity protection artifacts for internal name/address resolution queries. Supplemental Guidance: Provide data origin and integrity protection artifacts for internal name/address resolution queries. None.

NIST SP 800-171 Rev 3 control 03.13.12 (03.13.12 Collaborative Computing Devices and Applications) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.13.15 (03.13.15 Session Authenticity) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Communications Protection (SC) family. The

CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

SC-7.22 · Separate Subnets for Connecting to Different Security Domains Control Statement: Implement separate network addresses to connect to systems in different security domains. Supplemental Guidance: Implement separate network addresses to connect to systems in different security domains. The decomposition of systems into subnetworks (i.e., subnets) helps to provide the appropriate level of protection for network connections to different security domains that contain information with different security categories or classification levels.

References: [SP 800-39] (Organization, Mission/Business Process, and System Levels); [SP 800-160 v1] (Decision Management and Project Assessment and Control Processes); [NIST CSF] (Core [Identify, Protect, Detect, Respond, Recover Functions]). NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

CHAPTER THREE PAGE 76 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-37r2> 3.7 MONITOR MONITOR TASKS Table 8
provides a summary of tasks and expected outcomes for the RMF Monitor step. Applicable
Cybersecurity Framework constructs are also provided. TABLE 8: MONITOR TASKS AND OUTCOMES Tasks
Outcomes TASK M-1 SYSTEM AND ENVIRONMENT CHANGES · The information system and environment of
operation are monitored in accordance with the continuous monitoring strategy. [Cybersecurity
Framework: DE.CM; ID.GV] TASK M-2 ONGOING ASSESSMENTS · Ongoing assessments of control
effectiveness are conducted in accordance with the continuous monitoring strategy. [Cybersecurity
Framework: ID.SC-4] TASK M-3 ONGOING RISK RESPONSE · The output of continuous monitoring
activities is analyzed and responded to appropriately. [Cybersecurity Framework: RS.AN] TASK M-4
AUTHORIZATION PACKAGE UPDATES · Risk management documents are updated based on continuous
monitoring activities. [Cybersecurity Framework: RS.IM] TASK M-5 SECURITY AND PRIVACY REPORTING
· A process is in place to report the security and privacy posture to the authorizing official and
other senior leaders and executives. TASK M-6 ONGOING AUTHORIZATION · Authorizing officials
conduct ongoing authorizations using the results of continuous monitoring activities and
communicate changes in risk determination and acceptance decisions. TASK M-7 SYSTEM DISPOSAL · A
system disposal strategy is developed and implemented, as needed. Quick link to summary table
for RMF tasks, responsibilities, and supporting roles. SYSTEM AND ENVIRONMENT CHANGES TASK M-1
Monitor the information system and its environment of operation for changes that impact the
security and privacy posture of the system. Potential Inputs: Organizational continuous monitoring
strategy; organizational configuration management policy and procedures; organizational policy and
procedures for handling unauthorized system changes; security and privacy plans; configuration
change requests/approvals; system design Purpose The purpose of the Monitor step is to maintain an
ongoing situational awareness about the security and privacy posture of the information system and
the organization in support of risk management decisions.

SC-40.4 · Signal Parameter Identification Control Statement: Implement cryptographic mechanisms to
prevent the identification of [organization-defined parameter] by using the transmitter signal
parameters. Supplemental Guidance: Implement cryptographic mechanisms to prevent the identification
of [organization-defined parameter] by using the transmitter signal parameters. The implementation
of cryptographic mechanisms to prevent the identification of wireless transmitters protects against
the unique identification of wireless transmitters for the purposes of intelligence exploitation by
ensuring that anti-fingerprinting alterations to signal parameters are not predictable by
unauthorized individuals. It also provides anonymity when required. Radio fingerprinting techniques
identify the unique signal parameters of transmitters to fingerprint such transmitters for purposes
of tracking and mission or user identification.

Control SC-23: ements] and recognize only session identifiers that are system- generated.
Discussion: Generating unique session identifiers curtails the ability of adversaries to reuse
previously valid session IDs. Employing the concept of randomness in the generation of unique
session identifiers protects against brute-force attacks to determine future session identifiers.
Related Controls: AC-10, SC-12, SC-13. (4) SESSION AUTHENTICITY | UNIQUE SESSION IDENTIFIERS WITH
RANDOMIZATION [Withdrawn: Incorporated into SC-23(3).] (5) SESSION AUTHENTICITY | ALLOWED
CERTIFICATE AUTHORITIES Only allow the use of [Assignment: organization-defined certificate

authorities] for verification of the establishment of protected sessions. Discussion: Reliance on certificate authorities for the establishment of secure sessions includes the use of Transport Layer Security (TLS) certificates. These certificates, after verification by their respective certificate authorities, facilitate the establishment of protected sessions between web clients and web servers. Related Controls: SC-12, SC-13. References: [SP 800-52], [SP 800-77], [SP 800-95], [SP 800-113].

SC-7.7 · Split Tunneling for Remote Devices Control Statement: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [organization-defined parameter]. Supplemental Guidance: Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [organization-defined parameter]. Split tunneling is the process of allowing a remote user or device to establish a non-remote connection with a system and simultaneously communicate via some other connection to a resource in an external network. This method of network access enables a user to access remote devices and simultaneously, access uncontrolled networks. Split tunneling might be desirable by remote users to communicate with local system resources, such as printers or file servers. However, split tunneling can facilitate unauthorized external connections, making the system vulnerable to attack and to exfiltration of organizational information. Split tunneling can be prevented by disabling configuration settings that allow such capability in remote devices and by preventing those configuration settings from being configurable by users. Prevention can also be achieved by the detection of split tunneling (or of configuration settings that allow split tunneling) in the remote device, and by prohibiting the connection if the remote device is using split tunneling. A virtual private network (VPN) can be used to securely provision a split tunnel. A securely provisioned VPN includes locking connectivity to exclusive, managed, and named environments, or to a specific set of pre-approved addresses, without user control.

NIST SP 800-53 Rev 5 control SC-2.2 (Disassociability) summarizes the requirements for this control: SC-2.2 · Disassociability Control Statement: Store state information from applications and software separately. Supplemental Guidance: Store state information from applications and software separately. If a system is compromised, storing applications and software separately from state information about users' interactions with an application may better protect individuals' privacy.